CyberSecurity Notes 2

Created: **10/18/25**
Version 1.2

Recommended **Study Tools**

- **Ai**
    1. Get a downloadable version of these notes by asking for your preferred file format (**PDF** recommended).
    2. Once you have the file in a safe area, open an LLM (**ChatGPT** & **Claude**) and upload the file.
    3. It can quiz/test you, help you study, or give you a customizable podcast (**NoteBookLM**).

- **Domains**
    1. Use the **Doc. Outline** located to the left to find areas of interest
    2. Study on areas of interest to satisfaction
    3. (**Optional**) Use our dedicated program to study **here**.

Tips

1. If you want to find any term in this doc use (**Ctrl+F**) to search for any words/terms.
2. Important areas are located in the **Doc. Outline** on the left of this page.
3. You can save this Doc as a file to keep it **accessible locally**. It is also **available offline**
4. If you want to see how any content was changed inside the Doc, check **version history**

Positive. Negative. Neutral/Mixed. Informational. Important

Glossary

- **AAA** (**Authentication, Authorization, and Accounting**): A security framework to control access (Authentication), enforce policies (Authorization), and audit usage (Accounting).
- **Adversary**: An individual, group, organization, or government that conducts or has the intent to conduct detrimental activities. (**Synonym: Threat Actor**).
- **Alert Fatigue**: A condition experienced by security personnel overwhelmed by a large number of security alerts, leading to missed or ignored critical warnings.
- **APT** (**Advanced Persistent Threat**): A sophisticated, often state-sponsored, attack where an intruder gains unauthorized access and remains undetected for an extended period.
- **Asset**: Any data, device, or other component of the environment that supports information-related activities; something of value to the organization.
- **Attack Surface**: The sum of the different points (the "attack vectors") where an unauthorized user (the "attacker") can try to enter or extract data from an environment.
- **Baseline**: A documented, approved standard for configuration or performance used for comparison.
- **BCP** (**Business Continuity Plan**): A plan to ensure essential business functions can continue during and after a disruption. (**Related: DRP**).
- **Blue Team**: The internal security team responsible for defending against attacks. (**Contrast: Red Team**).
- **BYOD** (**Bring Your Own Device**): Policy allowing employees to use personal devices for work.

- **CIA Triad** (**Confidentiality, Integrity, Availability**): The three core principles of information security.
- **CSF** (**Cybersecurity Framework**): A set of standards, guidelines, and best practices to manage cybersecurity risk (**e.g., NIST CSF**).
- **Defense in Depth**: A security strategy using multiple layers of defense to protect assets. (**Synonym: Layering**).
- **DRP** (**Disaster Recovery Plan**): A documented process or set of procedures to recover IT infrastructure in the event of a disaster. (**Related: BCP**).
- **Encryption**: The process of converting plaintext into ciphertext to prevent unauthorized access.
- **Exploit**: A piece of software, data, or sequence of commands that takes advantage of a bug or vulnerability to cause unintended or unanticipated behavior.
- **Federation**: Establishing trust and shared authentication/authorization between separate domains or organizations.
- **Hardening**: The process of securing a system by reducing its attack surface (e.g., removing unnecessary software, changing defaults, applying patches).
- **Honeypot**: A security mechanism set up to detect, deflect, or study attempts at unauthorized use of information systems. It acts as bait.
- **IAM** (**Identity and Access Management**): Framework of policies and technologies for managing digital identities and controlling user access.
- **IDS/IPS** (**Intrusion Detection System / Intrusion Prevention System**): Systems that monitor network traffic for malicious activity. IDS detects and alerts; IPS attempts to block it.
- **Incident Response** (**IR**): The process an organization uses to respond to and manage a cybersecurity incident.

- **Indicator of Compromise** (**IoC**): Forensic data, such as system log entries or files, that identify potentially malicious activity on a system or network.
- **Least Privilege**: Granting only the minimum necessary permissions required to perform a task . (**See: Principle of Least Privilege**).
- **Log**: A record of events occurring within an organization's systems and networks.
- **MITM / MitM** (**Man-in-the-Middle**): An attack where the attacker secretly relays and possibly alters the communication between two parties who believe they are directly communicating.
- **MFA** (**Multi-Factor Authentication**): Using two or more different authentication factors (knowledge, possession, inherence) . (Often seen as **2FA** - **Two-Factor Authentication**).
- **NAC** (**Network Access Control**): Security solutions that enforce policies on devices accessing network resources.
- **NIST** (**National Institute of Standards and Technology**): US agency developing standards, including cybersecurity frameworks.
- **Non-Repudiation**: Assurance that someone cannot deny the validity of something (e.g., sending a message).
- **Patch**: A software update intended to fix bugs, address security vulnerabilities, or improve performance.
- **Penetration Testing** (**Pen Test**): An authorized simulated cyberattack on a computer system, performed to evaluate the security of the system.
- **Personally Identifiable Information** (**PII**): Information that can be used on its own or with other information to identify, contact, or locate a single person.
- **PKI** (**Public Key Infrastructure**): Framework for creating, managing, distributing, and revoking digital certificates.
- **Plaintext**: Unencrypted data. (**Synonym: Cleartext**).

- **Policy**: A set of rules or guidelines for an organization. (**Security Policy defines security objectives**).
- **Principle of Least Privilege**: Giving people the bare-minimum amount of power required of them. **See Least Privilege**.
- **QoS** (**Quality of Service**): Mechanisms to manage network resources and prioritize traffic types.
- **Red Team**: An external or independent group that challenges an organization's security by playing the role of an attacker. (**Contrast: Blue Team**).
- **Risk**: The potential for loss or damage when a threat exploits a vulnerability.
- **Shadow IT**: IT systems or software used within an organization without explicit approval.
- **SIEM** (**Security Information and Event Management**): Systems providing real-time analysis of security alerts generated by network hardware and applications.
- **SLA** (**Service Level Agreement**): Contract defining the level of service expected from a provider.
- **Social Engineering**: Manipulating people into performing actions or divulging confidential information.
- **SOC** (**Security Operations Center**): A centralized unit that deals with security issues on an organizational and technical level.
- **SSO** (**Single Sign-On**): Allows users to log in once to access multiple related systems.
- **Threat**: Any potential danger that could exploit a vulnerability to breach security and cause harm.
- **Threat Actor**: Entity responsible for a security incident. (Synonym: **Adversary**).
- **Threat Vector**: The path or means by which an attacker gains access.
- **Vulnerability**: A weakness in a system, process, or control that can be exploited by a threat actor.
- **Zero-Day**: A vulnerability or exploit that is unknown to the vendor or the public.

- **Zero Trust**: A security model assuming no implicit trust; access requires continuous verification.

Protocol Guide

This section serves as a central hub for all major protocols mentioned in cybersecurity.

Application Layer (L7) & Presentation (L6)

Protocol	Full Name	Port(s)	Function & Key Details
HTTP	Hypertext Transfer Protocol	80 (TCP)	Fetches web resources (HTML, images) . It is the foundation of web data exchange but is **unsecured**.
HTTPS	Hypertext Transfer Protocol Secure	443 (TCP)	The **secure** version of HTTP. It uses **TLS (SSL)** for encryption, authentication, and integrity.
DNS	Domain Name System	53 (UDP/TCP)	Translates human-readable domain names (e.g., https://www.google.com) into machine-readable IP addresses. **Recommended: Use "over HTTPS"/"over TLS" versions**
DHCP	Dynamic Host Configuration Protocol	67 (Server), 68 (Client) (UDP)	Automatically assigns IP addresses and other network configuration settings to devices on a network. **Unusually vulnerable if not maintained.**
FTP	File Transfer Protocol	20 (Data), 21 (Command) (TCP)	Transfers files between a client and server. It is **unencrypted**. Uses two separate channels and can operate in active or passive modes .
SFTP	Secure File Transfer Protocol	22 (TCP)	**Securely** transfers files. It is not related to FTP; instead, it runs over an **SSH** session, using a single channel .

TFTP	Trivial File Transfer Protocol	69 (UDP)	A simplified, **unsecure**, and connectionless file transfer protocol. Often used for network boot or backing up router configs.
SMB	Server Message Block	445 (TCP)	Allows sharing of resources (files, printers, serial ports) on a network. Primarily used by Windows; Linux uses **Samba** to interoperate/access shared files on a Windows server. **Be sure to use new versions**
SSH	Secure Shell	22 (TCP)	Provides **secure**, encrypted remote command-line access. **Replaced Telnet**. Also used as the underlying protocol for SFTP.
Telnet	Telnet	23 (TCP)	Provides unsecure, **unencrypted** remote command-line access. **Discouraged** due to its lack of security.
SMTP	Simple Mail Transfer Protocol	**25** (unencrypted), **465** (Implicit TLS), **587** (Explicit TLS)	Used to **send** email from a client or between email servers. **Use with TLS. Explicit TLS is secure when implemented correctly.**
IMAP	Internet Message Access Protocol	**143** (unencrypted), **993** (Secure/TLS)	Used to **access and manage** email on a server. It stores emails on the server, allowing synchronization across multiple devices. **Use with TLS**
POP3	Post Office Protocol (v3)	**110** (unencrypted), **995** (Secure/TLS)	Used to **retrieve** email from a server. It typically downloads emails to the client and then deletes them from the server. **Use with TLS**
SIP	Session Initiation Protocol	**5060** (TCP/UDP), **5061** (TLS)	Initiates, maintains, and terminates real-time communication sessions, such as VoIP calls. **Use with TLS**

RTP	Real-Time Protocol	Even UDP ports	Transports audio and video data in real-time for VoIP and streaming. **Secure RIP (SRTP) is preferable**
RTCP	Real-Time Transport Control Protocol	Odd UDP ports (RTP+1)	Provides out-of-band statistics and control information (like packet loss, jitter) for an RTP session. **Security relies on RTP (SRTCP)**
TLS	Transport Layer Security	N/A	The modern standard for encrypting connections. Provides **Encryption** (scrambles data), **Authentication** (proves server identity via certificates), and **Integrity** (ensures data is unchanged) . Replaced SSL.
SSL	Secure Sockets Layer	N/A	The predecessor to TLS. **Not Recommended due to vulnerabilities like downgrade attacks**.
S/MIME	Secure/Multipurpose Internet Mail Extensions	N/A	A standard for sending **encrypted** and digitally signed emails, using the X.509 certificate structure.

Network Management

Protocol	Full Name	Port(s)	Function & Key Details
NTP	Network Time Protocol	123 (UDP)	Synchronizes system clocks to a universal time source (UTC) . This is crucial for accurate log correlation across different devices. **Can be vulnerable to spoofing**
PTP	Precision Time Protocol	N/A	Provides high-precision time synchronization, far more accurate than NTP. Used in financial services, 5G, and industrial systems. **Security depends on network environment**
SNMP	Simple Network Management Protocol	161 (Poll), 162 (Trap) (UDP)	Monitors and manages network devices. A manager "polls" devices for data. Devices can send "traps" (alerts) without being polled . **v1/v2c: Unsecure**, use a simple "community string" for authentication . **v3: Secure**, provides Message Integrity, Authentication, and Encryption .
Syslog	System Log	514 (UDP)	A standard protocol for sending log messages from devices to a central "Syslog server". This centralizes log management. **Over UDP is unreliable and unencrypted**, **over TLS is secure**
CDP	Cisco Discovery Protocol	N/A (L2)	Discovers directly connected Cisco devices, their OS version, and IP address. **Can leak data. Cisco Proprietary**.
LLDP	Link Layer Discovery Protocol	N/A (L2)	Discovers directly connected devices, their OS version, and IP address . **Vendor-neutral (IEEE)**. **Can leak data, disable if not needed**

Transport (L4), Network (L3), & Data Link (L2)

Protocol	Full Name	Port(s)	Function & Key Details
TCP	Transmission Control Protocol	N/A (L4)	Provides **reliable, connection-oriented**, and error-checked delivery of a stream of bytes. It sets up a "**handshake**" before sending data. **Can be vulnerable to attacks**
UDP	User Datagram Protocol	N/A (L4)	Provides **connectionless, "best-effort"** data delivery. It is fast but **does not guarantee delivery, order**, or error-checking. Used by DNS, DHCP, NTP, SNMP, VoIP. **Can be vulnerable to attacks**
IP	Internet Protocol	N/A (L3)	Handles logical addressing (IP addresses) and the routing of packets from a source to a destination across networks. **Security handled by IPsec. Commonly used in Version 4 and Version 6.**
ICMP	Internet Control Message Protocol	N/A (L3)	Used by network devices to send error messages and operational information. The ping command is a common use of ICMP, but is sometimes disabled to prevent security issues. **Can be vulnerable to attacks**
ARP	Address Resolution Protocol	N/A (L2/L3)	Resolves Layer 3 (IP) addresses to Layer 2 (MAC) addresses. It essentially asks, "Who on the local network has this IP address?" **Extremely vulnerable to spoofing**
NDP	Neighbor Discovery Protocol	N/A (L3)	The **IPv6 equivalent of ARP**. It uses ICMPv6 to discover other devices on the same link.**Can be vulnerable if not implemented correctly**, but **has security enhancements**
IPsec	Internet Protocol Security	N/A (L3)	A suite of protocols used to **secure** IP communications by authenticating and encrypting each IP packet. Commonly used to create VPNs.

Routing Protocols

Protocol	Full Name	Port(s)	Function & Key Details
BGP	Border Gateway Protocol	179 (TCP)	An **Exterior Gateway Protocol (EGP)**. It manages how packets are routed *between* large networks (Autonomous Systems). It is the core routing protocol of the internet. **Vulnerable to route hijacking if not secure**
OSPF	Open Shortest Path First	N/A (L3)	An **Interior Gateway Protocol (IGP)**. Used to find the best (shortest) path for data *within* a single network (e.g., inside a corporation). **Not inherently secure**
RIP	Routing Information Protocol	N/A (L3)	An older IGP. Less efficient than OSPF. **V1 is insecure**, **V2 has basic authentication but is still less preferred**
EIGRP	Enhanced Interior Gateway Routing Protocol	N/A (L3)	An advanced IGP developed by Cisco. **Uses Diffusing Update Algorithm** (**DUAL**) **Cisco Proprietary**. **Can be secured**

Authentication Protocols

Protocol	Full Name	Port(s)	Function & Key Details
Kerberos	Kerberos	88 (TCP/UDP)	A **robust** network authentication protocol that works on the basis of "tickets" or timestamps to allow nodes to prove their identity. It is the default authentication method used by **Active Directory**.
RADIUS	Remote Authentication Dial-In User Service	1812/1813 (UDP)	A centralized authentication, authorization, and accounting (AAA) protocol. Often used for network access (e.g., Wi-Fi, VPN). **Use newer version and properly configure**
TACACS+	Terminal Access Controller Access-Control System Plus	49 (TCP)	A AAA protocol. It is similar to RADIUS but is **Cisco Proprietary**. A key difference is that it **separates Authentication, Authorization, and Accounting**, giving more flexibility.

Network+

Domain 1: Networking Fundamentals

Domain 1 is all about **Networking Fundamentals**, serving as **the essential foundation for all cybersecurity**. It covers **how devices connect and communicate**. The domain starts with **1.1 (Network Concepts & Topologies),** which introduces the basic building blocks like **LANs**, **MAC vs. IP addresses**, and the different "maps" a network can have, such as **Star** or **Mesh** topologies. Next, **1.2 (The OSI Model)** explains the conceptual 7-layer framework that devices use to package and send data, from the physical cables to the applications you see. Then, **1.3 (Internet & Cabling)** gets into the physical components, like different internet types (fiber, satellite) and the **Ethernet cables** that tie everything together. Finally, **1.4 (Network Storage & Databases)** explains how data is stored on the network, covering **NAS** devices and different database types like **RDBMS** and **NoSQL**. You can check if you're strong on this domain by reviewing the "Key Terms" in each section; if you can confidently explain what a router is, the purpose of the OSI model, and what a NAS does, you're in great shape.

1.1 Network Concepts & Topologies

Think of a network as a digital community. It's just a group of connected devices (like computers, protocols, and the transmission medium or cables) that agree to share data and resources. To make sure every device can understand each other, they use a set of rules called **protocols**. The "map" or layout of this community—how everything is physically or logically arranged—is called its **topology**.

Key Terms

- **Topology:** This is simply the "map" of the network. It defines how all the devices are arranged and connected, whether you're drawing it on a whiteboard (logical) or looking at the actual cables (physical).
- **LAN (Local Area Network):** This is your "local" network, all confined to one geographical spot, like a home, office, or school.
    - **SOHO:** A **S**mall **O**ffice or **H**ome **O**ffice network.
    - **Enterprise LAN:** A bigger, more complex network for a business or a school.
- **Datacenter:** This is a massive facility purpose-built to house tons of servers and network gear for big companies like Google or Meta.
- **Client-Server Network:** This is the most common model you'll see. You have a central **server** that provides resources (like files, web pages, or services), and all the other **client** devices (like your computer) connect to it to get those resources.
- **MAC Address:** Think of this as a device's permanent "Serial Number." It's a unique **Physical** or **Hardware** address that's **B**urned-**I**n-**A**ddress (BIA) right onto the network card. It's written in hexadecimal and is only used for communication on the *local* network (like devices on the same Wi-Fi).
- **IP Address:** This is the "mailing address" for your device. It's a **Logical** address that's assigned to the device and is used to get data from one network to another (from Point A to Point B across the internet).
- **Hub:** This is a basic, "dumb" **Layer 1** device. It's a simple box that connects multiple computers, but it has no intelligence. When it gets data, it just "shouts" it out to *every other device* plugged into it. This forces every computer to check if the message is for them, which creates a lot of unnecessary traffic.
- **Router:** This is a "smart" **Layer 3** device that connects different networks. It reads the logical IP addresses on data packets to send them to their correct destination. Unlike a hub, routers don't forward broadcast messages to everyone, which helps segment traffic and keep the network running efficiently.
- **Network Protocols:** These are the "rules of the road" for the network. They're a set of rules for how to exchange data in a structured way so all devices can understand each other.
    - **Addressing:** A key part of a protocol that describes where data messages should go (like an IP or MAC address).

    - **Encapsulation:** This describes how data messages should be "packaged up" for their trip across the network. Think of it like putting a letter in an envelope and writing the address on it.
- **ACL (Access Control List):** This is a "bouncer's list" for the network. It's a set of rules that controls which devices or users are allowed to access certain parts of the network or specific resources.
- **Redundancy (or Fault Tolerance):** This is a fantastic concept! It just means having extra, duplicate, or "backup" components (like multiple paths or devices). The goal is to make the network **fault-tolerant**, meaning it can keep running even if one part fails. This is the main **Pro** of a **Mesh Topology** and the exact opposite of a "single point of failure."
- **Single Point of Failure:** This is a component in your network that, if it breaks, takes the whole network (or a large part of it) down with it. It's a major weakness. In a **Star Topology**, the central hub or switch is a perfect example of this.
- **Scalability:** This term just refers to how easily your network can grow. A scalable network lets you add new computers and devices without a major redesign. This is a key factor when choosing a topology.
- **Broadcast:** This is like "shouting" a message to everyone on the network at once. **Hubs** are "dumb" and do this all the time, which creates a lot of noise. **Routers** are "smart" and *do not* forward these broadcasts, which helps keep different networks separate and quiet.

Network Topologies

Choosing the right map for your network depends on what you need: low cost, high reliability, or the ability to grow easily.

- **Mesh Topology:**
  - **Explanation:** In a full mesh, every single computer and network device is interconnected with *every other* device.
  - **Pros:** Super reliable! If one connection or path goes down, the data can just take a different route.
  - **Cons:** Extremely expensive and complicated to set up because of all the extra cables and connections.
- **Star Topology:**
  - **Explanation:** This is the most common one. All devices (like computers and printers) connect to one central "star" point, which is usually a hub or a switch. This central device is sometimes called a "concentrator".
  - **Pros:** Pretty cheap to implement and easy to manage.
  - **Cons:** It has a single point of failure. If that central hub or switch dies, the whole system (or at least that part of it) goes down.
- **Point-to-Point:**
  - **Explanation:** The simplest topology. It's just a dedicated, direct connection between two devices , like plugging a cable directly from one computer to another.
- **Duplex (Communication Mode):**
  - **Full Duplex:** Devices can "talk" and "listen" (send and receive data) at the exact same time. Think of it like a normal phone call.
  - **Half Duplex:** Devices can only do one thing at a time—either talk *or* listen. Think of it like a walkie-talkie where you have to say "over" to let the other person speak.

1.2 The OSI Model

Think of the **OSI Model** as a digital "assembly line" for sending data. It's a conceptual map that breaks down the complex, multi-step process of network communication into **seven distinct layers**. Each layer has one specific job to do before passing the data to the next. This standardized framework ensures all our different devices "speak the same language" and can work together to get the job done.

Key Terms

- **Bits:** The most basic unit of data, seen as a raw signal (the 1s and 0s) that is physically sent over a transmission medium.
- **Data Formatting:** The "translator" job of Layer 6. It converts data into a standard format (like ASCII) that any computer can understand and open.
- **Encryption/Decryption:** The process of scrambling (encrypting) and unscrambling (decrypting) data to keep it secure, which is handled at Layer 6.
- **Nodes:** A general term for any device on a network, such as a computer or a switch.
- **ASCII:** A standard for data formatting (Layer 6) that translates characters into numbers, allowing different computers to understand and display text.
- **Listening:** The state of a server or service that is actively waiting for an incoming connection on a specific port number (e.g., a web server "listens" on Port 80).
- **Logical Addresses:** The term for IP addresses (Layer 3), which are "logical" because they are assigned and can be changed, unlike the physical MAC address.
- **Repeater:** A Layer 1 device that receives a signal, cleans it, and re-transmits it to extend the distance it can travel.
- **Source Port & Destination Port:** When your computer sends data, the **Destination Port** is the "apartment number" on the server (e.g., Port 443 for a secure website). The **Source Port** is the temporary **ephemeral port** on your computer that acts as the "return address" for the server's reply.
- **Transmission Mediums:** The physical "stuff" the signal travels over at Layer 1, such as **fiber optics**, copper cables (**electricity**), or **wireless radio waves**.
- **TCP (Transmission Control Protocol):** The **reliable**, connection-oriented Layer 4 protocol. It acts like a tracked package, error-checking to make sure all data arrives correctly and in order.
- **UDP (User Datagram Protocol):** The **unreliable** (or "best-effort"), connectionless Layer 4 protocol. It's very fast because it doesn't error-check, making it great for things like DNS lookups or VoIP, where speed is more important than perfect accuracy.

The **OSI (Open Systems Interconnection) model** is a "conceptual framework". That's a fancy way of saying it's a map that helps us understand the complex process of network communication by dividing it into seven distinct, manageable layers. Think of it as an assembly line for your data.

- **Layer 1 - Physical:**
  - **Explanation:** This is the "hardware" layer. It's responsible for the *actual* transmission and receipt of the raw signal—the bits of data. If you can touch it, it's probably Layer 1.
  - **Includes:** The physical topology (the layout of the cables) , the transmission mediums (like **fiber optics** , copper **electricity** , or **wireless** radio waves), and the physical interfaces (like an **Ethernet** port or **Bluetooth**).
  - **Devices:** Transceiver , Repeater , **Hub** , Media Converter.
- **Layer 2 - Data Link (Switch):**
  - **Explanation:** This layer handles communication *within* the local network. It's responsible for transferring data between nodes (devices) on the same logical segment. This is the layer that uses **MAC addresses** to identify devices.
- **Layer 3 - Network (Router):**
  - **Explanation:** This is the "postal service" layer. It's responsible for getting data from Point A to Point B *across different networks*. This is where **IP addresses** (the "logical addresses") are used and where all the "routing" decisions happen.
- **Layer 4 - Transport:**
  - **Explanation:** This layer manages the "shipping" of the data. It identifies what the data is and ensures it gets there in one piece. This is where the two main protocols, **TCP** (reliable, like a tracked package) and **UDP** (unreliable but fast, like a postcard), operate.
  - **Includes:** This layer uses **port numbers** (like HTTP Port 80) to identify which specific application or service the data is intended for.
- **Layer 5 - Session:**
  - **Explanation:** This layer is the "manager" of the conversation. It's responsible for establishing the connection, managing the data transfer "session," and then properly tearing down that connection when everything is finished.
- **Layer 6 - Presentation:**
  - **Explanation:** This layer is the "universal translator." It takes the data from the application and transfers it into a standard format that other computers can understand and open. This is also where tasks like **encryption/decryption** (like TLS) and data formatting (like ASCII) happen.
- **Layer 7 - Application:**
  - **Explanation:** This is the "user" layer, the one you actually see and interact with. It provides an interface for your software (like a web browser or email client) to use the network.

Port Numbers

You can think of port numbers as the "apartment numbers" for a computer. In our earlier analogies, the **IP address** (**Layer 3**) gets data to the right "building" (your device). But once the data arrives, how does your device know whether to send it to your web browser, your email app, or your online game?

That's where **port numbers** (a **Layer 4** concept) come in.

A port number is simply an identifier for a specific application or service running on a device. Both **TCP** and **UDP** use them to make sure data gets to the right place.

Here's how it works:

1. **The Server Side (Listening):** A server "listens" for requests on specific, standardized ports. These are often called **"Well-Known Ports"** (ranging from 0 to 1023). For example:
    - A web server (HTTP) listens on **Port 80 (TCP)**.
    - A secure web server (HTTPS) listens on **Port 443 (TCP)**.
    - A DNS server listens on **Port 53 (UDP/TCP)**.
2. **The Client Side (Requesting):** When your computer (the client) wants to visit a website, it creates a data packet.
    - **Destination:** The packet is addressed to the web server's **IP Address** and **Destination Port 80**.
    - **Source:** Your computer opens a temporary, random port for *itself* (like Port 51000). This is called an **ephemeral port**, and it acts as the "return address" for the conversation.

When the server sends the website data back, it addresses it to your IP address and your ephemeral port (51000). Your operating system sees that port 51000 belongs to your web browser, and *voilà*—the webpage loads in the right application.

A Deeper Look: Port Number Specifics (Optional)

Let's expand on the "apartment number" analogy for **port numbers**. As we covered, an **IP address** (**Layer 3)** gets your data to the right "building" (your device), and the **port number** (**Layer 4**) tells the device which "apartment" (or specific application) that data is for.

But the system is a bit more organized than just random numbers. The total range of available ports is **0 to 65535**, and these are divided into three main categories:

---

1. Well-Known Ports (0 - 1023)

These ports are standardized and reserved for the most common, universal internet services. Your computer and web servers automatically know that a specific service "lives" at this port number. It's why you don't have to type `:80` every time you visit a website.

Common Examples from your Protocol Guide:

- **FTP**: Uses **Port 21** for commands and **Port 20** for data.
- **DNS**: Uses **Port 53** **(UDP/TCP)** to translate domain names into IP addresses.
- **DHCP**: Uses **Port 67** (server) and **Port 68** (client) to automatically assign IP addresses.
- **SNMP**: Uses **Port 161** **(UDP)** for polling and **Port 162** **(UDP)** for traps.
- **HTTPS**: Uses **Port 443** **(TCP)** for *secured*, encrypted websites.
- **SMB**: Uses **Port 445** **(TCP)** for Windows file and printer sharing.

---

2. Registered Ports (1024 - 49151)

These ports are "registered" with the **Internet Assigned Numbers Authority** (**IANA**) for specific applications or services. They aren't as universally "known" as the first group, but they prevent two different programs from trying to use the same port. A company might register a port for its database software, a specific online game, or other proprietary services.

---

3. Dynamic / Private / Ephemeral Ports (49152 - 65535)

This is the range your computer (the client) uses to create its "return address." When your browser (the client) reaches out to a web server on its **Destination Port 80**, your computer will randomly assign itself a temporary, unused port from this high range (like `51000`) as its **Source Port**.

This is called an **ephemeral port** (meaning temporary). When the server replies, it sends the data back to your IP address and that "return" port (`51000`), so your computer knows the data belongs to your web browser and not another app.

1.3 Internet & Cabling

Domain 1.3 is where we leave the logical world of software and hit the physical world of hardware. This section covers the "nuts and bolts" of the network—literally the wires, glass, and radio waves that allow us to connect to the internet. It explains how data travels from your ISP to your building, where the responsibility for that wiring shifts from them to you (the Demarc), and the specific rules we use to terminate Ethernet cables (TIA/EIA 568B) so that data flows correctly. If you can identify the color order of an Ethernet cable and know exactly where to plug in a router during an outage, you have mastered this section.

Key Terms

- **CPE (Customer Premises Equipment):** This is a catch-all term for any equipment located at the customer's site (your house or office). It includes the modem, router, and any switches or firewalls provided by the ISP. Even though it sits in your building, it is often owned and managed by the Service Provider.
- **Demarcation Point (Demarc):** The "line in the sand" for troubleshooting. It is the precise physical point where the Service Provider's responsibility ends and the Customer's responsibility begins. In a home, this is often the Network Interface Device (NID) box on the side of the house. In an office, it's often a patch panel in the Main Distribution Frame (MDF).
- **IXP (Internet Exchange Point):** A massive physical facility (data center) where different Internet Service Providers (ISPs) and Content Delivery Networks (CDNs like Netflix or Google) connect their networks together to swap traffic directly, reducing latency and cost.
- **UTP (Unshielded Twisted Pair):** The standard copper Ethernet cable found in almost every LAN. It uses pairs of wires twisted together to cancel out EMI (Electromagnetic Interference) and Crosstalk.
- **RJ-45:** The standard 8-pin connector used for Ethernet cables.
- **TIA/EIA 568B:** The most common wiring standard in the US and commercial environments for terminating Ethernet cables. It dictates the specific order of the 8 colored wires inside the connector.
- **TIA/EIA 568A:** An older standard, often used in government or legacy installations. The only difference from 568B is that the Green and Orange pairs are swapped.
- **Straight-Through Cable:** An Ethernet cable where both ends are wired with the same standard (usually both 568B). This is used to connect unlike devices (e.g., PC to Switch).
- **Crossover Cable:** An Ethernet cable where one end is 568A and the other is 568B. This reverses the transmit and receive pairs, allowing you to connect like devices (e.g., PC to PC or Switch to Switch) without a hub.
- **Pinout Order (568B):** You must memorize this sequence: 1. White-Orange, 2. Orange, 3. White-Green, 4. Blue, 5. White-Blue, 6. Green, 7. White-Brown, 8. Brown. Note that the Green pair is split around the Blue pair.

- ## Internet Connection Types

Not all internet connections are created equal. The medium (what the signal travels through) dictates the speed, latency, and reliability of the connection.

Fiber Optic:

- **Explanation:** Uses pulses of light traveling through hair-thin glass or plastic strands.
- **Pros:** Extremely high bandwidth and very low attenuation (signal loss over distance). It is immune to Electromagnetic Interference (EMI) because it uses light, not electricity.
- **Cons:** Expensive to install and fragile.

Cable (Coaxial):

- **Explanation:** Uses the same copper cabling as cable television. Data is transmitted via electrical signals.
- **Pros:** Widely available and reasonably fast.
- **Cons:** It is a "shared medium," meaning your speed and bandwidth might drop during peak hours if many neighbors are online.

Cellular (4G/5G):

- **Explanation:** Uses radio waves from cell towers to transmit data.
- **Pros:** High mobility; you aren't tied to a specific building or location.
- **Cons:** Variable speeds based on signal strength and tower congestion. Data caps are often enforced.

Satellite:

- **Explanation:** Beams data from a dish on your roof to a satellite in orbit.
    - **GEO (Geostationary):** Satellites sit high in orbit (22,000 miles). They cover a huge area but suffer from high latency.
    - **LEO (Low Earth Orbit):** Newer tech (like Starlink) where satellites orbit much closer (300-1,200 miles), offering better speeds and lower latency.
- **Pros:** Provides connectivity in remote areas where cables cannot reach.
- **Cons:** Generally higher latency (especially GEO) and can be affected by weather conditions (rain fade).
        1.

1.4 Network Storage & Databases

Now that we have the cables run (1.3) and the protocols to move data (1.2), we need a place to actually *put* that data. Domain 1.4 covers **Network Storage**—devices dedicated to holding files—and **Databases**, which are specialized systems for organizing information so it can be easily retrieved. Whether you are backing up configs to a local NAS or pulling user profiles from a cloud NoSQL database, understanding these backend systems is critical for a network professional.

Key Terms

- **NAS (Network Attached Storage):** A dedicated file storage device that connects to the network, allowing multiple users and devices to store and retrieve files from a central location. It is essentially a specialized computer optimized for saving data.
- **RDBMS (Relational Database Management System):** The traditional "Excel-spreadsheet style" database. It stores data in structured tables with rows and columns. It relies on strict rules and relationships between data.
- **SQL (Structured Query Language):** The standard programming language used to communicate with, update, and retrieve data from an RDBMS.
- **NoSQL (Not Only SQL):** A modern database type designed for flexibility and speed. Instead of rigid tables, it stores data in documents or key-value pairs. It is the backbone of many modern web apps and big data.
- **Scalability:** The ability of a system to handle growing amounts of work.
    - **Vertical Scaling:** Making a single server stronger (adding more RAM/CPU). RDBMS usually scales this way.
    - **Horizontal Scaling:** Adding *more* servers to share the load. NoSQL excels at this.
- **API (Application Programming Interface):** A software intermediary that allows two applications to talk to each other. In NoSQL, data is often accessed via APIs over the web (HTTPS) rather than direct database queries.

Network Storage

NAS (Network Attached Storage)

Think of a NAS as a "private cloud" in your office. It’s not just a hard drive; it’s a fully functional server stripped down to do one job: serve files.

- **Explanation:** A NAS is a standalone appliance that connects directly to the network (usually via Ethernet). It has its own IP address and file sharing protocols.
- **Components:**
    - **Hardware:** It contains a processor (CPU), RAM, and slots (bays) for multiple hard drives.
    - **Software:** It runs a lightweight Operating System (usually a customized version of Linux) to manage file permissions and network connections.
- **Use Case:** Perfect for Small Office/Home Office (SOHO) environments for file sharing, media streaming, and automated backups.
- **Benefits:**
    - **Centralization:** Everyone accesses the same files; no more emailing versions back and forth.
    - **Fault Tolerance:** Most NAS devices use RAID (Redundant Array of Independent Disks), so if one drive fails, your data is still safe.

Databases

Data isn't always just files; sometimes it's millions of tiny records (like usernames, passwords, or transaction history). For that, we need a database.

RDBMS (Relational Database Management Systems)

This is the "Old Guard" of databases, but it is still the industry standard for financial and business data where accuracy is paramount.

- **Structure:** Data is organized into **Tables** with Rows and Columns (like a spreadsheet).
    - **Unique IDs:** Each row usually has a unique identifier (Primary Key) to distinguish it from others.
    - **Relationships:** Tables can be linked. For example, a "Customer" table can be linked to an "Orders" table by the Customer ID.
- **Language:** Uses **SQL** (Structured Query Language) to write and read data.
- **Security:** Connections to the database can be encrypted via **TLS** to prevent eavesdropping.
- **Pros:** Extremely reliable and consistent. Great for complex queries (e.g., "Show me all customers who bought a red shirt in July").

- **Cons:** Rigid structure. If you want to change the data format, you have to modify the entire table structure.

NoSQL Database Service

As web applications (like Facebook or Amazon) grew massive, traditional RDBMS became too slow and rigid. NoSQL was the answer.

- **Structure:** Flexible. Instead of tables, it uses **Documents**, **Key-Value Pairs**, or **Graphs**. You can dump data in without pre-defining exactly what it looks like.
- **Access:** Often accessed via **APIs over HTTPS**. This makes it very "web-native" and easy for developers to use in cloud applications.
- **Scalability:** Designed to grow **Horizontally**. Instead of buying a super-computer (Vertical), you just add more cheap servers to the cluster.
- **Pros:** Highly scalable and flexible. Fast for simple lookups.
- **Cons:** Less consistent than RDBMS. Not ideal for complex accounting where every penny must be tracked in relation to everything else.

Domain 2: Wireless Networking

Domain 2 shifts the focus to **Wireless Networking**, moving away from physical cables to radio waves and signal transmission. The domain starts with **2.1 (Core Concepts & Standards)**, which lays the groundwork for 802.11 standards (Wi-Fi), CSMA/CA, and how devices avoid collisions in the air. Next, **2.2 (Other Wireless Technologies)** expands the scope beyond Wi-Fi to cover Cellular networks (4G/5G) and Satellite communications. Then, **2.3 (WLAN Topologies & Components)** details the hardware, such as antennas and controllers, and how they are arranged in Infrastructure or Mesh modes. **2.4 (WLAN Planning & Security)** is a massive section covering how to secure these networks with WPA3 and how to perform site surveys. Finally, **2.5 (Wireless Performance & Troubleshooting)** focuses on fixing issues like signal attenuation, interference, and roaming problems. You can check if you're strong on this domain by reviewing the "Key Terms"; if you can confidently explain the difference between **WPA2 and WPA3**, how **CSMA/CA** works, and the benefits of **MU-MIMO**, you're ready to proceed.

2.1 Core Concepts & Standards

Wireless networking relies on a strict set of standards to ensure that a phone from Apple can connect to a router from Cisco. The primary standard we use is **IEEE 802.11**, commonly known as Wi-Fi.

Key Terms

- **IEEE 802.11:** The set of technical standards that defines how radio waves are used to communicate. It ensures compatibility between different vendors.
- **Wi-Fi Alliance:** The organization that certifies products. If you see the "Wi-Fi" logo on a box, it means the device has been tested to adhere to 802.11 standards and will work with other certified devices.
- **CSMA/CA (Carrier Sense Multiple Access with Collision Avoidance):**
    - **The Problem:** In a wireless network, devices can't "hear" collisions like they can on a wired Ethernet cable.
    - **The Solution:** Devices use a "listen before you talk" method.
        - **Carrier Sense:** The device listens to see if the airwaves are free.
        - **Collision Avoidance:** Before sending data, the device sends a small "RTS" (Request to Send) signal. It waits for other devices to receive this and back off before transmitting its actual data. This minimizes the chance of two devices talking over each other.
- **MU-MIMO (Multi-User, Multiple Input, Multiple Output):**
    - **Old Way (SU-MIMO):** Older routers could only talk to one device at a time, switching between them rapidly.
    - **New Way (MU-MIMO):** Allows an Access Point (AP) with multiple antennas to send data to *multiple* devices at the exact same time. This significantly improves efficiency in crowded areas.
- **Band Steering:** A smart feature on dual-band (2.4 GHz and 5 GHz) or tri-band routers. It automatically detects if a device is capable of faster speeds and "steers" it to the less crowded 5 GHz or 6 GHz band, leaving the slower 2.4 GHz band for older devices.
- **Channels:**
    - The 2.4 GHz band is crowded and only has 11 channels in the US.
    - **The Golden Rule:** To avoid interference, always use **Channel 1, 6, or 11**. These are the only three channels that do not overlap with each other.

Wi-Fi Generations (Standards)

You will need to know the evolution of these standards, specifically the speeds and frequencies they operate on.

Standard	Marketing Name	Frequencies	Theoretical Speed	Key Technology
802.11b	--	2.4 GHz	11 Mbps	**DSSS/CCK:** Old and slow.
802.11g	--	2.4 GHz	54 Mbps	**OFDM:** A major leap in efficiency.
802.11n	Wi-Fi 4	2.4 & 5 GHz	600 Mbps	**MIMO:** Introduced multiple antennas; **Channel Bonding:** Combined channels for more speed.
802.11ac	Wi-Fi 5	5 GHz Only	~1 Gbps+	**Beamforming:** Focuses the signal directly at the device rather than spraying it everywhere.
802.11ax	Wi-Fi 6 / 6E	2.4, 5, & 6 GHz	10 Gbps	**OFDMA:** Splits channels into smaller sub-channels for better efficiency; **1024-QAM:** Packs more data into each wave.
802.11be	Wi-Fi 7	2.4, 5, & 6 GHz	40 Gbps+	(Newer Tech): Extremely high throughput and low latency.

2.2 Other Wireless Technologies

While Wi-Fi (802.11) is great for local connectivity inside a building, we often need to connect devices over much larger distances or in areas where running cables isn't possible. Domain 2.2 covers these "Other Wireless Technologies," focusing heavily on **Cellular Networks** (how your phone connects to the internet) and **Satellite Internet** (how we get data from space). Understanding the evolution from 3G to 5G and the difference between "high orbit" and "low orbit" satellites is crucial for modern network planning.

Key Terms

- **Cellular Network:** A radio network distributed over land areas called "cells," each served by at least one fixed-location transceiver (cell tower).
- **LTE (Long Term Evolution):** The technical standard for 4G wireless communication. It marked the shift to a fully IP-based network.
- **5G (Fifth Generation):** The latest cellular standard designed to connect virtually everyone and everything together, including machines, objects, and devices.
- **Latency:** The time it takes for data to travel from source to destination. This is the "killer" issue for satellite internet.
- **Line-of-Sight:** The requirement that the transmitting and receiving antennas must be able to "see" each other without obstruction (used in Microwave and Satellite links).
- **IoT (Internet of Things):** Smart devices (fridges, sensors, watches) that connect to the internet. 5G was specifically built to handle the massive density of these devices.

Cellular Generations

Cellular technology has evolved in "Generations." You need to know the progression because you will still encounter older devices in the field (like legacy IoT sensors).

Generation	Marketing Name	Key Characteristic	Typical Speed	Primary Use Case
2G	GSM / CDMA	**Digital Voice:** The first digital cellular signals. Introduced SMS (texting).	< 50 Kbps	Voice calls & simple texts. (Mostly obsolete).
3G	EVDO / HSPA	**Mobile Internet:** The first generation to support decent web browsing and apps.	~2 Mbps	Basic email, GPS, and light web browsing.
4G	**LTE / LTE-A**	**High-Speed Data:** A fully IP-based network. Offered speeds comparable to home broadband.	Up to 300 Mbps	Streaming HD video, video calling, and fast downloads.
5G	5G NR	**Massive Connectivity:** Ultra-high speeds and ultra-low latency. Uses "Millimeter Waves" for speed.	**Up to 20 Gbps**	4K/8K streaming, Autonomous Vehicles, Smart Cities, AR/VR.

The Big Shift: 3G vs. 4G/5G

- **3G** was a hybrid of "Circuit Switching" (like old phone lines) for voice and "Packet Switching" for data.
- **4G/LTE** and **5G** are **all-IP networks**. Even your voice calls (VoLTE) are just data packets, similar to a VoIP call.

Satellite Internet

When you are in a rural area or on a ship in the middle of the ocean, cell towers and fiber cables can't reach you. That is where Satellite Internet comes in.

Microwave Satellite (Terrestrial)

Before we go to space, we often use "Terrestrial Microwave" links.

- **Explanation:** Uses two dish antennas pointing directly at each other to shoot a beam of data.
- **Requirement: Strict Line-of-Sight.** If a tree grows in front of the dish, the connection drops.
- **Use Case:** Connecting two buildings on a campus or providing internet to a rural tower.

GEO (Geostationary Earth Orbit)

This is the "Old School" satellite internet (like HughesNet or Viasat).

- **Position:** The satellite sits **22,236 miles** above the equator. Because it matches the Earth's rotation, it appears to stay fixed in the sky.
- **Pros:** One satellite covers a massive area (a whole continent). You only need 3 to cover the whole Earth.
- **Cons: Extreme Latency.** The signal has to travel 22,000 miles up and 22,000 miles down. This creates a delay (approx. 600ms) that makes real-time gaming or Zoom calls nearly impossible.

LEO (Low Earth Orbit)

This is the "New School" satellite internet (like **Starlink** or OneWeb).

- **Position:** Satellites orbit much closer, only **300 to 1,200 miles** up.
- **Pros: Low Latency.** Because they are close, the delay is similar to a cable connection (~30-50ms), making gaming and video calls smooth.
- **Cons:**
    - **Small Coverage:** Each satellite sees only a tiny patch of ground.
    - **Moving Targets:** The satellites are moving fast across the sky (they don't stay still). You need a constellation of *thousands* of satellites and a motorized dish that can track them to maintain a connection.

2.3 WLAN Topologies & Components

We know the language (802.11) and the medium (Radio Waves). Now, Domain 2.3 covers how we actually *arrange* these devices to build a functional network. Whether you are setting up a single router in a coffee shop or a massive mesh network across a university campus, you need to understand the different **Topologies** (the layout map) and **Components** (the hardware pieces) that make it work.

Key Terms

- **SSID (Service Set Identifier):** This is the technical name for the "Network Name" you see on your phone (e.g., "Starbucks_Free_WiFi"). It can be up to 32 characters long.
- **BSSID (Basic Service Set Identifier):** While the SSID is the name, the BSSID is the unique **MAC Address** of the specific Access Point (AP) radio you are connected to.
    - *Analogy:* SSID is the name of the store ("Walmart"). BSSID is the specific cash register you are standing at.
- **ESSID (Extended Service Set Identifier):** When you have a large building with 50 Access Points, you want them all to have the *same* name so users can roam freely. The ESSID is that common network name used across the entire group of APs.
- **WDS (Wireless Distribution System):** A system that enables the interconnection of Access Points wirelessly. It allows you to expand a network using multiple APs without needing a wired backbone to link them (essentially a wireless repeater mode).

WLAN Topologies

Just like wired networks have "Star" and "Mesh" maps, wireless networks have specific modes of operation.

Infrastructure Mode

This is the standard Wi-Fi setup used in 99% of homes and offices.

- **Explanation:** All client devices (laptops, phones) connect to a central **Access Point (AP)**. The AP acts as the "hub" or gateway to the wired network.
- **Structure:** It forms a logical **Star Topology**.
- **Pros:** Easy to manage, scalable, and secure.

Ad Hoc (IBSS - Independent Basic Service Set)

- **Explanation:** A decentralized, peer-to-peer network where devices connect directly to each other without an Access Point.
- **Use Case:** Apple AirDrop is a modern example. Historically used for temporary file transfers between two laptops.
- **Cons:** Does not scale well; if you add too many devices, collisions increase drastically.

Mesh Topology (WMN - Wireless Mesh Network)

- **Explanation:** Nodes (APs) connect to other nodes to form a web. Only one node needs a physical wire to the internet; the rest act as repeaters, hopping data from one to another until it reaches the destination.
- **Use Case:** Smart Cities, large warehouses, or home systems like Eero/Orbi where running cables to every room is impossible.
- **Pros:** Self-healing! If one node dies, traffic re-routes through a neighbor.
- **Cons:** Latency increases with every "hop" the data makes.

Point-to-Point (PtP)

- **Explanation:** A dedicated high-speed wireless link between two specific locations.
- **Use Case:** "Building Bridging." Connecting a main office to a warehouse across the street without digging a trench for fiber.
- **Requirement:** Uses highly directional antennas and requires strict line-of-sight.

WLAN Components

Antennas

The shape of the antenna dictates where the signal goes.

- **Omnidirectional (Dipole):**
    - **Pattern:** Radiates signal 360 degrees, like a donut or a lightbulb.
    - **Use Case:** Standard ceiling-mounted APs intended to cover a whole room.
- **Unidirectional (Directional):**
    - **Pattern:** Focuses the signal in a tight beam, like a flashlight.
    - **Types:** Yagi, Parabolic Dish.
    - **Use Case:** Point-to-Point links or forcing signal down a long hallway.
- **Dual-Polarized:**
    - **Explanation:** Transmits signals in both vertical and horizontal orientations.
    - **Why?** Mobile devices (phones) are constantly rotating. Dual-polarization ensures the signal stays strong whether you hold your phone in portrait or landscape mode.

Wireless Controllers

In an enterprise with 500 Access Points, you cannot log into each one individually to change the password. You need a brain.

- **Explanation:** A central appliance (physical or cloud-based) that manages all APs on the network.
- **Key Functions:**
    - **Centralized Config:** Push a new SSID or security update to 500 devices with one click.
    - **Roaming:** Helps hand off clients from one AP to the next smoothly.
    - **VLAN Assignment:** Can assign users to different VLANs (e.g., Guests to VLAN 10, Staff to VLAN 20) based on their login credentials.
    -

2.4 WLAN Planning & Security

You can buy the best hardware in the world (2.3), but if you place it poorly or leave it unsecured, your network is useless. Domain 2.4 covers the **Planning** phase (making sure the signal goes where it needs to) and the **Security** phase (making sure hackers stay out). This section details the modern standards like **WPA3**, the "Enterprise" way of logging in, and the specific attacks you need to defend against.

Key Terms

- **Site Survey:** The physical process of planning a wireless network. It involves walking the building to check for interference and determine the best placement for Access Points.
- **Heat Map:** A color-coded map generated by a site survey that visualizes signal strength. Red usually means "hot" (strong signal), while blue/green means weak.
- **WPA3 (Wi-Fi Protected Access 3):** The latest and most secure security standard. It replaced WPA2 to fix major vulnerabilities like offline password cracking.
- **SAE (Simultaneous Authentication of Equals):** The technical "handshake" method used by WPA3 personal mode. It prevents attackers from downloading your handshake and cracking the password offline.
- **802.1X (EAP):** The standard used for "Enterprise" authentication. Instead of one shared password for everyone, users log in with their own unique username and password.
- **RADIUS Server:** The "bouncer" server that checks your username/password during an 802.1X login.
- **Captive Portal:** A web page that pops up before you can access the internet (common in hotels/airports). You have to accept terms or pay a fee to proceed.
- **Rogue Access Point:** An unauthorized router plugged into your network (e.g., an employee bringing a router from home).
- **Evil Twin:** A specific type of Rogue AP that *impersonates* a real network (e.g., a hacker sets up a hotspot named "Starbucks_Free_WiFi" to steal your data).

WLAN Planning

Before you mount a single AP, you need a plan.

Site Surveys & Heat Maps

You cannot just guess where to put routers. Walls, glass, and microwaves all destroy Wi-Fi signals.

- **The Process:** A technician walks the floor plan with a laptop and specialized software.
- **The Output (Heat Map):**
  A visual map showing:
  - **Coverage:** "Do we have signal in the breakroom?"
  - **Interference:** "Is the microwave in the kitchen killing the signal?"
  - **SNR (Signal-to-Noise Ratio):** We want high signal and low noise.

Roaming & Beacons

- **Beacon Frames:** Every AP broadcasts a "heartbeat" signal roughly 10 times a second. This beacon announces: "I am Network X, I support these speeds, and I use WPA3 security."
- **Roaming:** When you walk from the lobby to your desk, your phone sees the signal from AP-A getting weaker and AP-B getting stronger. It decides to "jump" to AP-B. This is client-side decision making, but it relies on consistent signal overlap (usually 15-20%).

Wireless Security Protocols

You must know the difference between the generations of security. **WEP** and **WPA** are dead/obsolete. Focus on WPA2 and WPA3.

WPA2 (Wi-Fi Protected Access 2)

- **Status:** The standard for the last 15 years, but now showing its age.
- **Encryption:** Uses **AES (Advanced Encryption Standard)**, which is very strong.
- **Weakness:** Vulnerable to "Offline Dictionary Attacks" (KRACK attack). If a hacker captures the "handshake" when you connect, they can take it home and try millions of passwords against it until it cracks.

WPA3 (Wi-Fi Protected Access 3)

- **Status:** The modern standard (2018+).
- **Key Features:**

1. **SAE (Simultaneous Authentication of Equals):** Replaces the old handshake. It makes offline password cracking impossible. Even if your password is "password123", a hacker cannot brute-force it offline.
2. **Forward Secrecy:** If a hacker *does* steal the password later, they cannot use it to decrypt traffic they recorded in the past.
3. **Individualized Encryption:** In open networks (like a coffee shop supporting WPA3 Enhanced Open), your traffic is encrypted even without a password.

Enterprise Authentication (802.1X)

In a home, everyone shares the same "Pre-Shared Key" (PSK). In a large company, that is a security nightmare. If one employee leaves, you'd have to change the Wi-Fi password for everyone.

The Solution: WPA2/WPA3-Enterprise.

- **How it works:** Users log in with unique credentials (User/Pass or a Smart Card).
- **The "AAA" Process:**
    1. **Supplicant (The Device):** Your laptop asks to join. "Here is my username/password."
    2. **Authenticator (The AP):** The Access Point acts as a guard. It takes the credentials but *cannot* verify them itself. It passes them to the server.
    3. **Authentication Server (RADIUS):** The backend server (like Active Directory) checks the database. "Yes, Bob is an active employee." It sends an "Access Accept" message back to the AP.

Wireless Attacks

Rogue Access Point

- **Scenario:** An employee wants better Wi-Fi in their office, so they bring a router from home and plug it into the wall jack.
- **Risk:** This "Rogue" router doesn't have the company's security policies. It bypasses the firewall, creating a massive backdoor for hackers.

Evil Twin

- **Scenario:** A hacker sits in the parking lot or lobby. They set up a Pineapple (hacking device) and broadcast a Wi-Fi network with the *exact same name* (SSID) as your corporate network.
- **Attack:** Your phone sees "Corporate_WiFi" with a stronger signal (because the hacker is close) and connects to it automatically.
- **Result:** The hacker now sits in the middle (Man-in-the-Middle) and can intercept all your traffic or steal your login credentials.

Deauthentication Attack (Deauth)

- **Scenario:** A hacker sends a spoofed "Disconnect" command to your laptop, pretending to be the router.
- **Goal:**
    1. **Denial of Service:** Just to be annoying and knock you offline.

2. **Capture the Handshake:** When your device immediately tries to reconnect, the hacker records that "handshake" to try and crack the password offline (effective against WPA2).

2.5 Wireless Performance & Troubleshooting

We have built the network (2.3) and secured it (2.4), but users are still complaining that "the Wi-Fi is slow." Domain 2.5 is all about troubleshooting. This section covers the physics of why signals get weak (**Attenuation**), the difference between "Speed" and "Throughput," and the common enemies of wireless performance like **Interference** and **Overcapacity**. If you can look at a -80 dBm signal and know immediately that it's unusable, you are ready for this section.

Key Terms

- **Throughput:** The *actual* amount of data successfully moved from point A to point B. This is different from "Bit Rate" (the theoretical max speed). Throughput is always lower due to overhead and errors.
- **Attenuation:** The weakening of a signal as it travels through the air or passes through objects. A concrete wall causes high attenuation; a drywall causes low attenuation.
- **RSSI (Received Signal Strength Indicator):** A measurement of how strong the signal is at the device. It is measured in decibels-milliwatts (dBm).
  - **Scale:** It is a negative number. Closer to 0 is better.
  - **-30 dBm:** Perfect signal (standing next to the router).
  - **-67 dBm:** Good signal (minimum for Voice over Wi-Fi).
  - **-80 dBm:** Unusable/Dead zone.
- **SNR (Signal-to-Noise Ratio):** The comparison of the "Good Stuff" (Signal) to the "Bad Stuff" (Background Noise).
  - *Analogy:* Signal is your friend talking. Noise is the loud music in the bar. You need the friend to be louder than the music to understand them.
- **Refraction:** The bending of a radio wave as it passes through a medium of different density (like glass or water).

Common Wireless Issues

1. Insufficient Coverage (Dead Zones)

- **Problem:** Users in the corner office drop calls.
- **Cause:** The signal has attenuated too much passing through walls or distance.
- **Troubleshooting:**
  - Check the **RSSI**. If it's below -75 dBm, the signal is too weak.
  - **Solution:** Add more APs, increase transmit power (carefully!), or move the AP closer to the users.

2. Interference & Channel Overlap

Wireless is a shared medium. If everyone talks at once, no one is heard.

- **Co-Channel Interference (CCI):**
  - **Scenario:** Two Access Points near each other are both on **Channel 6**.
  - **Result:** They have to wait for each other to finish talking (like two people trying to use one walkie-talkie). This drastically slows down the network.
  - **Fix:** Change one AP to Channel 1 or 11.
- **Adjacent Channel Interference (ACI):**
  - **Scenario:** One AP is on Channel 6, and a neighbor is on Channel 7.
  - **Result:** Their frequencies partially overlap and "bleed" into each other. This is essentially noise that ruins the SNR.
  - **Fix:** Stick to the non-overlapping channels (1, 6, 11).
- **EMI (Electromagnetic Interference):**
  - **Scenario:** Non-Wi-Fi devices emitting radio waves.
  - **Culprits:** Microwave ovens (kills 2.4 GHz), Bluetooth devices, Cordless phones, and fluorescent lights.
  - **Fix:** Move the AP away from these sources or switch users to the 5 GHz band (which is less prone to this interference).

3. Roaming Issues

Roaming is when a device disconnects from AP-A and connects to AP-B as you walk down the hall.

- **Sticky Client:**
  - **Problem:** A user walks from the Lobby (AP-A) to the Breakroom (AP-B). They are standing *right under* AP-B, but their phone refuses to let go of the weak signal from the Lobby.
  - **Result:** Slow speed and dropped packets.
  - **Fix:** Adjust the "Roaming Aggressiveness" on the client driver, or lower the transmit power of the Lobby AP so the device is forced to switch sooner.

4. Overcapacity (Device Saturation)

- **Problem:** The Wi-Fi works great at 8 AM but crawls at 10 AM when everyone arrives.
- **Cause:** Too many devices on a single AP. Wi-Fi is half-duplex (only one device talks at a time). If 50 people try to talk, 49 are waiting.
- **Fix:**
    - **Load Balancing:** Use a Wireless Controller to spread users across multiple APs.
    - **High-Density APs:** Upgrade to Wi-Fi 6 (802.11ax) which handles density much better using OFDMA technology.

Domain 3: Network Management & Monitoring

Domain 3 moves us from "building" the network to "maintaining" it. This is the daily life of a Network Admin. It starts with **3.1 (Organizational Policies & Documentation)**, which covers the essential paperwork like Change Management and Network Diagrams that keep the chaos in check. Next, **3.2 (Host Discovery & Monitoring)** explains how we find devices on the network using tools like Nmap and standard protocols like LLDP. Then, **3.3 (Management Protocols & Logging)** details the specific languages devices use to report their health, such as SNMP for monitoring, NTP for time sync, and Syslog for error reporting. Finally, **3.4 (Packet & Traffic Analysis)** gets into the weeds of forensic analysis, using tools like Wireshark to inspect individual packets. You can check if you're strong on this domain if you can explain the difference between **SNMPv2 and v3**, recite the **Syslog severity levels**, and read a **Logical Network Diagram**.

3.1 Organizational Policies & Documentation

Effective network management relies on strong documentation. If you don't know what you have or how it's configured, you can't secure it.

Key Terms

- **Configuration Management (CMS):** The systematic process of identifying, documenting, and maintaining all network devices. It ensures that every router and switch is accounted for.
- **Configuration Item (CI):** Any specific asset that requires management, such as a single Router, Server, or even a critical software application.
- **Baseline:** The "Golden Standard." This is a snapshot of your network performance or configuration when everything is working perfectly. You use this to compare against when things go wrong.
- **Configuration Drift:** The slow, often unnoticed deviation from the Baseline. This happens when admins make "quick fixes" without documenting them, eventually leading to a messy, unmanageable network.
- **IPAM (IP Address Management):** The software or method used to track IP addresses. It prevents IP conflicts by recording which IPs are assigned to which devices.

1. Agreements & Contracts

In the business world, you rarely trust a handshake. You rely on specific documents to define expectations.

- **SLA (Service Level Agreement):**
  - **Definition:** A legally binding contract between a Service Provider (ISP) and a Customer.
  - **Key Components:** It defines **measurable metrics**, such as "99.99% Uptime" or "2-hour response time for hardware failure."
  - **Consequences:** If the provider fails to meet these metrics, the SLA defines the financial penalty (e.g., free service credits).
- **MSA (Master Service Agreement):**
  - **Definition:** The "Umbrella Contract." It is a long-term agreement that sets the baseline legal terms (payment terms, liability, confidentiality) between two parties.
  - **Purpose:** Once signed, you can start multiple small projects (SOWs) without re-negotiating the legal terms every single time.
- **MOU (Memorandum of Understanding):**
  - **Definition:** A "Gentleman's Agreement." It outlines a mutual intent to work together but is **not** usually legally binding.
  - **Use Case:** Common between two departments in the same company or two government agencies. "The IT Dept agrees to support the HR Dept's new software."
- **SOW (Statement of Work):**
  - **Definition:** A specific, project-based document. It details exactly *what* work will be done, *when* it is due, and *how much* it costs.
  - **Example:** "Vendor X will install 50 Wireless Access Points by Friday, August 12th."

2. Personnel & Security Policies

People are the weakest link in security. These policies dictate human behavior.

- **AUP (Acceptable Use Policy):**
  - **The Rulebook:** This is the document every employee signs when hired. It tells them what they *can* and *cannot* do on corporate equipment.
  - **Examples:** "Do not use the VPN to watch Netflix," "Do not use company email for personal business," "No gambling sites."
- **NDA (Non-Disclosure Agreement):**
  - **Purpose:** A legal contract that protects sensitive data. If an employee or contractor sees trade secrets (like a new product design), they are legally banned from telling anyone or taking that data to a competitor.
- **Privileged User Agreement (PUA):**
  - **Target:** Network Admins, Domain Admins, and Root users.

    - **Purpose:** Admins have the power to read anyone's email or delete any file. This agreement holds them to a higher standard of ethics. "Just because you *can* read the CEO's email doesn't mean you *should*."
- **BYOD (Bring Your Own Device):**
    - **Challenge:** Employees want to use their personal iPhones for work email.
    - **Policy:** Defines the rules for personal devices. Usually requires the installation of **MDM (Mobile Device Management)** software so IT can remotely wipe the phone if it is lost.
- **Remote Access Policy:**
    - **Rules:** Dictates how users connect from home. "You must use the VPN," "You must have Antivirus installed," "You must use Multi-Factor Authentication (MFA)."

3. Standard Operating Procedures (SOPs)

- **Definition:** Detailed, step-by-step instructions for routine tasks.
- **Why:** If the main Network Engineer gets hit by a bus, a junior admin should be able to pick up the SOP and keep the network running.
- **Examples:** "How to create a new user," "How to backup the firewall," "Disaster Recovery checklist."

4. Onboarding & Offboarding

Managing the lifecycle of an employee's access is critical for security.

- **Onboarding (Hiring):**
    - **Identity:** Create accounts (AD, Email).
    - **Provisioning:** Assign hardware (Laptop, Phone) and specific permissions (Principle of Least Privilege).
    - **Training:** User signs the AUP and takes security awareness training.
- **Offboarding (Firing/Quitting):**
    - **Immediate Action: Disable accounts immediately.** (Do not delete them yet, just disable/lock them so data is preserved but access is stopped).
    - **Recovery:** Retrieve laptop, badge, and keys.
    - **Exit Interview:** Remind them of their NDA obligations.

5. Network Documentation

- **Physical Network Diagram:**
    - Shows the "Real World." Rack numbers, cabling paths, port numbers, and physical hardware locations.
- **Logical Network Diagram:**
    - Shows the "Data Flow." IP addresses, Subnets, VLAN IDs, and Routing Protocols.
- **Asset Management:**

- **Inventory:** Tracking every piece of hardware.
- **RFID/Asset Tags:** Stickers with barcodes or chips stuck to laptops/routers to track their physical location.

3.2 Host Discovery & Monitoring

Before you can manage the network, you have to know what is *on* the network.

Key Terms

- **Network Discovery:** The active scanning of a network to find live hosts (computers, printers, IoT devices).
- **Performance Monitoring:** Tracking the health of the network by watching metrics like CPU load, temperature, and bandwidth usage.
- **Availability Monitoring:** The simple "Is it alive?" check. If a server stops responding to Pings, it is "Unavailable."

Discovery Protocols

How do devices find each other automatically?

- **CDP (Cisco Discovery Protocol):**
    - **Type:** Proprietary (Cisco devices only).
    - **Function:** A Cisco router can automatically see other connected Cisco devices, their IOS version, and IP address.
    - **Security Risk:** It broadcasts sensitive info in cleartext. Best practice is to disable it on interfaces facing the internet.
- **LLDP (Link Layer Discovery Protocol):**
    - **Type:** Vendor-Neutral (Standard IEEE 802.1AB).
    - **Function:** The exact same job as CDP, but it works on ANY brand of equipment (Juniper, HP, Dell, etc.).

Discovery Tools (Scanning)

Nmap (Network Mapper) The industry-standard tool for network discovery.

- **Ping Sweep (-sn):** Sends a tiny signal to every IP in a range to see who replies. "Who is home?"
- **Service Detection (-sV):** Probes open ports to see what software is running. "Is port 80 running Apache or IIS?"
- **OS Fingerprinting (-O):** Guesses the Operating System (Windows vs. Linux) based on how the device responds.

Performance Metrics

- **Bandwidth:** The *theoretical* max speed of the cable (e.g., 1 Gbps).
- **Throughput:** The *actual* speed you are getting (e.g., 850 Mbps).
- **Latency:** The delay (time) it takes for a packet to get from A to B.
- **Jitter:** The *variation* in latency. (High jitter ruins VoIP calls).
- **Error Rate:** The percentage of packets that are corrupted or dropped. High errors usually mean a bad cable or severe interference.

3.3 Management Protocols & Logging

Devices need a standardized way to tell you how they are doing.

Key Terms

- **Log Correlation:** The process of taking logs from different devices (Firewall, Switch, Server) and matching them up by timestamp to see the full picture of an event.
- **Trap:** An unsolicited message sent by a device (Agent) to the SNMP Manager to alert it of a specific event (like a link going down).
- **MIB (Management Information Base):** The internal database structure on a network device that holds all the metrics (CPU, bandwidth, errors) that SNMP can query.
- **OID (Object Identifier):** The specific address string that points to a specific variable within the MIB (e.g., `.1.3.6.1...` might equal "CPU Temperature").
- **Stratum:** A level in the NTP hierarchy indicating the distance from the reference clock. Stratum 0 is the source; Stratum 1 connects to 0, etc.

NTP (Network Time Protocol)

- **Port:** UDP 123.
- **Purpose:** Synchronizes clocks on all devices.
- **Why it matters: Log Correlation.** If your Firewall says an attack happened at 10:00 AM, but your Server says it happened at 10:05 AM because its clock is fast, you cannot prove they are the same event.
- **Stratum Levels:**
    - **Stratum 0:** The atomic clock (source).
    - **Stratum 1:** A server directly connected to the atomic clock.
    - **Stratum 2:** A server getting time from Stratum 1. (The higher the number, the further from the source).

SNMP (Simple Network Management Protocol)

- **Purpose:** A way for a central "Manager" to ask "Agents" (routers/switches) for data.
- **Ports:**
    - **UDP 161:** The Manager *polls* (asks) the device. "What is your CPU usage?"
    - **UDP 162:** The Device sends a *Trap* (alert) to the Manager. "Help! My interface just went down!"
- **Components:**
    - **MIB (Management Information Base):** The structured database on the device that stores the data.
    - **OID (Object Identifier):** The specific address of a variable in the MIB (e.g., `.1.3.6.1...` might equal "CPU Temperature").
- **Versions:**
    - **v1/v2c: Insecure.** Sends community strings (passwords) in cleartext.
    - **v3: Secure.** Adds Authentication (verify user) and Encryption (hide data). Always use v3.

Syslog

- **Port:** UDP 514 (Standard) or TCP 6514 (Secure).
- **Purpose:** A standard way for devices to send event logs to a central server.
- **Severity Levels:** You must memorize the order (0 is worst, 7 is least).
    - **0 - Emergency:** System is unusable. (The house is on fire).
    - **1 - Alert:** Immediate action needed.
    - **2 - Critical:** Critical condition.
    - **3 - Error:** Error condition.
    - **4 - Warning:** Warning condition.
    - **5 - Notice:** Normal but significant.
    - **6 - Informational:** Just info (e.g., "User logged in").
    - **7 - Debug:** Detailed info for developers.

SIEM (Security Information and Event Management)

A tool that ingests logs from everywhere (Syslog, SNMP, Firewalls) to find threats.

1. **Aggregation:** Collecting logs from 50 different sources into one pile.
2. **Correlation:** Connecting the dots. "I see a badge swipe at the door (Physical) AND a login attempt on the server (Logical) at 2 AM. That is suspicious."
3. **Alerting:** Sending an email/SMS to the admin.

3.4 Packet & Traffic Analysis

Sometimes logs aren't enough. When you need to see exactly what is happening on the wire, you move to packet analysis. This is the deepest level of troubleshooting.

Key Terms

- **Promiscuous Mode:** A network card setting that allows it to "listen" to all traffic on the wire, not just packets addressed to itself. Essential for packet capture.
- **Deep Packet Inspection (DPI):** Looking into the actual "payload" (contents) of a packet, rather than just the headers.
- **Metadata:** Data *about* data. In networking, this is Flow data (who, where, when) without the actual packet contents.
- **Port Mirroring (SPAN):** A switch feature that copies traffic from one port to another for monitoring purposes.
- **Network TAP:** A hardware device inserted into a cable that physically splits the signal to send a copy to an analyzer.

1. Packet Capture (Deep Packet Inspection)

This involves intercepting and recording the actual raw data (frames/packets) crossing the network.

- **The Concept:** Think of this as a **Wiretap**. You record the entire conversation, word-for-word.
- **Promiscuous Mode:** A network card setting that tells the device to "read ALL traffic" on the wire, not just traffic addressed to itself. This is required for packet sniffing.

Packet Capture Tools:

- **Wireshark:** The industry-standard **GUI** tool.
  - **Features:** Color-coded packets, deep filtering (e.g., `ip.addr == 192.168.1.5`), and the "Follow TCP Stream" feature which rebuilds a fragmented data stream into readable text/HTML.
  - **Use Case:** Forensic analysis, finding cleartext passwords, diagnosing specific application errors.
- **tcpdump:** The industry-standard **Command Line (CLI)** tool.
  - **Platform:** Linux/Unix/macOS.
  - **Features:** Lightweight and fast. Great for headless servers where you don't have a mouse.
  - **Use Case:** Quick "on the box" captures or scripting.

2. Flow Analysis (Metadata)

Capturing every single packet is heavy on storage and CPU. Sometimes you just need the summary.

- **The Concept:** Think of this as a **Phone Bill**. It tells you *who* called *whom*, *when*, and for *how long*, but it does NOT record what they said.
- **Protocols:**
  - **NetFlow:** Developed by Cisco.
  - **IPFIX (IP Flow Information Export):** The standardized version of NetFlow.
  - **sFlow:** A sampled version (looks at 1 out of every 1000 packets).
- **Use Case:** "Who is using all the bandwidth?", "Is there a DDoS attack?", "Who are the Top Talkers?"

3. How to Capture Traffic (Getting the Data)

You can't just plug a laptop into a switch and expect to see everyone's traffic (switches isolate traffic). You need a specific method to "copy" the data to your analyzer.

A. Port Mirroring (SPAN - Switched Port Analyzer)

- **Explanation:** A software configuration on a switch that tells it: "Take a copy of all traffic on Port 1 and send it to Port 24 (where the sniffer is)."
- **Pros:** Free (just a command), easy to set up remotely.
- **Cons:**
    - **Dropped Packets:** If the switch gets busy, it will drop the SPAN traffic first to protect the real traffic.
    - **Timing:** It alters the timing of frames slightly.

B. Network TAP (Test Access Point)

- **Explanation:** A physical hardware device inserted between two routers/switches. It physically splits the light/electricity to send a copy to the monitoring tool.
- **Pros: 100% Fidelity.** It never drops packets, even at full speed. It captures physical layer errors (Layer 1) that a switch chip might discard.
- **Cons:** Expensive hardware. Requires you to unplug cables to install it (network downtime).

Domain 4: Security Principles & Governance

Domain 4 shifts gears from technical configuration to the high-level strategy that guides every security decision. It starts with 4.1 (Fundamental Security Concepts), which defines the core goals of security using the CIA Triad. Next, 4.2 (Security Controls) explains the specific tools and rules we use to achieve those goals, categorizing them by how they work (Technical vs. Managerial) and when they work (Preventive vs. Detective). 4.3 (Cybersecurity Frameworks) introduces the NIST CSF, the gold standard for organizing a security program. Finally, 4.4 (Access Control Principles & Models) covers the "who gets in" rules, detailing concepts like Least Privilege, Zero Trust, and the specific models like MAC, DAC, and RBAC.

4.1 Fundamental Security Concepts

These are the non-negotiable goals of information security. Every firewall rule, policy, or locked door exists to support one of these three pillars.

Key Terms

- **CIA Triad:** The three core principles of security. If you lose one, you are no longer secure.
    - **Confidentiality:** Keeping secrets secret. Ensuring that data is only accessed by authorized people.
        - *Attack:* Data Breach, Snooping.
        - *Defense:* Encryption, Permissions.
    - **Integrity:** Keeping data accurate. Ensuring that data has not been tampered with or corrupted.
        - *Attack:* Man-in-the-Middle modification, File Corruption.
        - *Defense:* Hashing, Digital Signatures.
    - **Availability:** Keeping data accessible. Ensuring that authorized users can get to the data when they need it.
        - *Attack:* Denial of Service (DoS), Ransomware.
        - *Defense:* Redundancy, Backups, Load Balancing.
- **Non-Repudiation:** The concept that someone cannot deny having taken an action.
    - *Example:* If you sign a contract with a Digital Signature, you cannot later claim "I never signed that," because the cryptography proves it was your private key.
    - *Goal:* Accountability and legal proof.

4.2 Security Controls

A "Control" is any mechanism used to mitigate risk. We categorize them in two ways: by **Category** (what it is) and by **Function Type** (what it does).

Control Categories (What they are)

1. **Managerial (Administrative):** "The Paperwork." Controls that provide oversight, governance, and rules.
    - *Examples:* Security Policies, Hiring Procedures, Background Checks, Training Plans.
2. **Operational:** "The People." Controls enforced by humans doing their daily jobs.
    - *Examples:* Security Guards, Incident Response Teams, Awareness Training.
3. **Technical (Logical):** "The Tech." Controls implemented via software or hardware.
    - *Examples:* Firewalls, Antivirus, Encryption, ACLs, IDS/IPS.
4. **Physical:** "The Real World." Controls that stop you from physically touching the asset.
    - *Examples:* Fences, Locks, Cameras (CCTV), Motion Detectors, Bollards.
    -

Control Types

- **Preventive:** Proactive controls designed to **stop** a security breach *before* it occurs .
    - **Example:** A firewall blocking a malicious IP address.
- **Deterrent:** Controls that **warn** an attacker they may be caught, discouraging the attack.
    - **Example:** A "Warning: Area Under Surveillance" sign or a login banner warning of legal penalties .
- **Detective:** Controls implemented to **identify and record** (log) security incidents *as they occur* .
    - **Example:** Logs generated by a firewall, an IDS alert, or real-time system monitoring . (This *finds* the problem; it doesn't *stop* it).
- **Corrective:** Controls applied *after* an incident to **fix** the issue, minimize impact, and mitigate damage .
    - **Example:** A backup system that restores data damaged during an intrusion.
- **Compensating:** A "backup" control that serves as a second line of defense when a primary control fails or isn't working properly.
- **Directive:** Controls that enforce rules of behavior through policies or contracts. They *direct* employees on correct actions.
    - **Example:** Standard Operating Procedures (SOPs), employee contracts, or an Acceptable Use Policy (AUP).

4.3 Cybersecurity Frameworks

You don't have to invent security from scratch. Organizations use **Frameworks**—standardized guides—to ensure they aren't missing anything.

Key Terms

- **NIST Cybersecurity Framework (CSF):** The US government's standard for managing cyber risk. It organizes security tasks into 5 functions.
- **Gap Analysis:** The process of comparing your *Current State* ("Where we are") with your *Desired State* ("Where the Framework says we should be"). The difference is the "Gap" you need to fill.

The 5 NIST Functions

1. **Identify:** "Know what you have." Asset Management, Risk Assessment. You can't protect what you don't know exists.
2. **Protect:** "Lock the doors." Implementing controls to ensure service delivery. Access Control, Awareness Training, Encryption.
3. **Detect:** "Watch the cameras." continuous monitoring to spot a cybersecurity event. IDS, SIEM, Log Analysis.
4. **Respond:** "Fight the fire." Taking action once an incident is detected. Mitigation, Analysis.
5. **Recover:** "Clean up the mess." Restoring services and learning lessons to prevent it from happening again.

4.4 Access Control Principles & Models

This section defines **IAM (Identity and Access Management)**—the science of verifying users and deciding what they are allowed to touch.

Key Terms

The AAA Framework

- **Identification:** Claiming an identity. "Hi, I am User JSmith." (Typing your username).
- **Authentication:** Proving you are who you say you are. "Here is my password." (Verifying the claim).
- **Authorization:** What you are allowed to do. "JSmith is allowed to Read files, but not Delete them." (Permissions).
- **Accounting:** Tracking what you did. "JSmith read File-A at 10:05 AM." (Logs).

Core Principles

- **Principle of Least Privilege:** Users should have the **bare minimum** access needed to do their job, and nothing more. If a user only needs to read a file, do not give them "Write" or "Admin" access.
- **Zero Trust:** "Never Trust, Always Verify." A security model that assumes the network is already compromised. Even if you are inside the office firewall, you must re-authenticate for every resource you try to access.

Access Control Models

How does the system decide who gets access?

1. DAC (Discretionary Access Control)

- **Concept:** The **Owner** decides.
- **Example:** Microsoft Windows File Sharing. You create a folder, you are the owner, and you right-click to "Share" it with Bob.
- **Pro:** Flexible and easy for users.
- **Cons:** Weak security; users might share secrets accidentally.

2. MAC (Mandatory Access Control)

- **Concept:** The **System** decides based on Labels.
- **Example:** Military/Government. Files are labeled "Top Secret." Users are labeled "Top Secret Clearance." If the labels match, you get in. If not, you are blocked. The user has *no choice* in this.
- **Pro:** Extremely secure.
- **Cons:** Very rigid and hard to manage.

3. RBAC (Role-Based Access Control)

- **Concept:** Access is based on your **Job Title (Role)**.
- **Example:** Corporate environments. "Nurses" get access to medical records. "Billing" gets access to invoices. If you hire a new nurse, you just add them to the "Nurses" group.
- **Pro:** Best for large organizations with high turnover.

4. ABAC (Attribute-Based Access Control)

- **Concept:** The most flexible model. It looks at **Who, What, Where, and When**.
- **Logic:** "Allow access IF User = Manager AND Time = 9am-5pm AND Location = Office."
- **Pro:** Highly granular context-aware security.

5. Rule-Based Access Control

- **Concept:** Access is determined by a static set of if/then rules.
- **Example:** Firewalls. "If traffic is on Port 80, Allow. If traffic is on Port 23, Deny."

Access Control Models

- **Discretionary Access Control (DAC):** An access control model where the *owner* of a resource manages its Access Control List (ACL) and decides who has access. (e.g., You create a file and "Share" it with a coworker).
- **Mandatory Access Control (MAC):** An inflexible, *system-defined* model. Resources (objects) and users (subjects) are allocated a clearance level or label (e.g., "Top Secret," "Secret"). The system enforces rules based on these labels .
- **Role-Based Access Control (RBAC):** An access control model where permissions are managed by *administrators*, not owners. Users are assigned to "roles" (e.g., "Sales," "HR," "IT Admin"), and permissions are granted to those roles.
- **Attribute-Based Access Control (ABAC):** A highly flexible model that evaluates a set of "attributes" (e.g., What is the user's role? What time of day is it? What is their physical location?) to determine if access should be granted.
- **Rule-Based Access Control:** A non-discretionary model based on a set of operational rules or restrictions, like a firewall. (e.g., "Block all traffic from IP X," "Allow port 80 traffic") .

4.5 Enterprise Network Architecture

We simplify hardware into two categories: Nodes that *create* data and Nodes that *forward* it.

Node Types

- **Host Nodes (Endpoints):** Devices that initiate data transfers (Servers, Laptops, Phones).
- **Intermediary Nodes:** Traffic cops. Switches, Routers, and Firewalls that move data.

Security Control Placement

You can't just place tools randomly.

1. **Network Border:** The "Front Door." Primary spot for **Preventative Controls** (Firewalls) to block traffic before it enters.
2. **Hosts (Endpoints):** Devices need layered protection. Critical spot for **Preventative** (Host Firewall), **Detective** (Logs), and **Corrective** (Antivirus) controls.
3. **Inside the Perimeter:** The trusted internal network. Best for **Detective Controls** (IDS/TAPs) to sniff out lateral movement.

Active vs. Passive Controls

- **Active Controls:** "Hands-on." They participate in the data exchange and can modify/block it.
    - *Examples:* Firewalls, Routers, IPS.
- **Passive Controls:** "Hands-off." They operate silently and are transparent to the network. They just watch.
    - *Examples:* **Network TAP** (Test Access Point), **Switch Port Mirroring (SPAN)**.

4.6 Enterprise Security Appliances

The specific "boxes" (or VMs) we put in the rack to secure the network.

1. Firewalls & Unified Threat Management (UTM)

- **Firewall:** A preventative control that filters traffic based on rules.
- **UTM (Unified Threat Management):** An "All-in-One" appliance. It bundles multiple functions into one box:
    - Firewall
    - IDS/IPS
    - URL Filtering (Web Filter)
    - Spam Filter
    - Content Inspection (Antivirus)
- **WAF (Web Application Firewall):** Specialized firewall that inspects HTTP/S traffic to stop web attacks (SQL Injection, XSS). Often found on Load Balancers.

2. Proxies & Gateways

- **Proxy Server:** An intermediary. You talk to the Proxy; the Proxy talks to the Internet.
    - **Functions:** Anonymity, **Caching** (storing web pages to speed up access), and **Content Filtering**.
- **Jump Server:** A highly hardened server used as a single entry point for admins. You RDP into the Jump Server, and *then* manage other servers. It isolates the admin path.

3. Load Balancers

- **Function:** Distributes incoming traffic across a "farm" of servers.
- **Benefit: Fault Tolerance**. If Server A dies, the Load Balancer sends traffic to Server B.
- **Types:** Layer 4 (IP/Port based) vs. Layer 7 (Content/URL based).

4. Intrusion Detection & Prevention

- **IDS (Intrusion Detection System):**
    - **Passive.** Monitors traffic via a TAP or SPAN port.
    - **Action:** Alerts/Logs only. Does **not** block.
    - **Types:** Signature-based (known threats), Heuristic/Behavioral (anomalies).
- **IPS (Intrusion Prevention System):**
    - **Active.** Placed **In-Line** (traffic flows *through* it).
    - **Action:** Can block/drop packets immediately if a threat is detected.

4.7 Access Control Lists (ACLs)

An ACL is a list of permissions attached to an object or a network interface. On routers, they act as packet filters.

Firewall/Router ACLs

- **Function:** Filter traffic based on IP, Port, and Protocol.
- **Implicit Deny:** "The golden rule." If traffic isn't explicitly allowed, it is blocked. Every ACL ends with a hidden `Deny All`.
- **Standard ACLs:** Filter only by **Source IP**. (Layer 3).
- **Extended ACLs:** Filter by Source IP, Destination IP, Port, and Protocol. (Layer 3 & 4).

ACL Operation & Wildcard Masks

- **Sequential Order:** The router reads rules Top-to-Bottom. Once a match is found, it stops checking.
- **Wildcard Mask:** Used in Cisco ACLs to define a range of IPs.
    - *Rule:* **0** means "Must Match", **1** means "Don't Care".
    - *Shortcut:* The Wildcard is usually the **inverse** of the Subnet Mask. (e.g., Subnet `255.255.255.0` -> Wildcard `0.0.0.255`).
    - *Example:* `0.0.0.0` tells the mask to check *all* bits (exact host match).

Domain 5: Threats, Attacks & Vulnerabilities

Domain 5 shifts our focus from defense to offense. To secure a network, you must think like the attacker. This domain covers the "who," "how," and "what" of cyberattacks. It starts with **5.1 (Threat Landscape)**, identifying the different types of enemies—from bored teenagers (Script Kiddies) to government-funded military units (APTs). Next, **5.2 (General Attack Strategies)** explains the lifecycle of a hack, from the initial research (Reconnaissance) to the actual breach (Exploit). **5.3 (Social Engineering)** details the art of hacking humans, covering tactics like Phishing and Tailgating where no code is required. Finally, **5.4 (Malware)** breaks down the software weapons used to cause damage, distinguishing between Viruses, Worms, Trojans, and Ransomware.

5.1 Threat Landscape

Before we look at the *tools*, we must look at the *people* holding them. The "Threat Landscape" describes the variety of entities that might want to harm your organization.

Key Terms

- **Threat Actor:** The person or entity behind an attack. They are categorized by their *motivation* (why they do it) and their *resources* (how much money/skill they have).
- **APT (Advanced Persistent Threat):** The most dangerous type of attacker.
  - **Advanced:** They use custom, high-level tools (often Zero-Days).
  - **Persistent:** They are not "smash and grab" robbers; they hide in your network for months or years to steal data slowly.
  - **Who:** Usually Nation-States (governments).
- **Zero-Day:** A vulnerability that the software vendor (like Microsoft or Apple) does not know about yet. There is "zero days" time to fix it before it can be exploited.
- **Attack Surface:** The total sum of all the different points (vectors) where an attacker could try to enter.
  - *Example:* A server with 10 open ports has a larger attack surface than a server with 2 open ports.
- **Shadow IT:** Hardware or software used by employees without IT approval.
  - *Risk:* If Bob installs a cheap Wi-Fi router under his desk, IT can't patch it, making it a perfect backdoor for hackers.

Types of Threat Actors

1. **Script Kiddies:**
    - **Skill:** Low. They cannot write code.
    - **Method:** They download pre-made hacking tools (scripts) from the internet and run them randomly.
    - **Motivation:** Attention, "for the lulz," or basic vandalism.
2. **Hacktivists:**
    - **Motivation:** Ideological or Political.
    - **Goal:** They don't usually want to steal money; they want to send a message.
    - **Tactics:** Website defacement or DDoS attacks (denying service to a company they hate).
    - *Example:* Anonymous.
3. **Insider Threats:**
    - **The Danger:** They are already inside the firewall and have valid credentials.
    - **Malicious Insider:** A disgruntled employee sabotaging data for revenge.
    - **Unintentional Insider:** A naive employee who clicks a phishing link or leaves a password on a sticky note. (This is the most common cause of breaches).
4. **Organized Crime:**
    - **Motivation:** Money. Pure and simple.
    - **Tactics:** Ransomware, credit card theft, selling data on the dark web.
5. **Nation-States:**
    - **Motivation:** Espionage, geopolitical advantage, or cyber-warfare.
    - **Resources:** Unlimited funding and the best hackers in the world.

5.2 General Attack Strategies

Attacks rarely happen instantly. Advanced attackers follow a structured lifecycle, often referred to as the "Cyber Kill Chain" or attack methodology. Understanding these steps allows you to disrupt the attack before damage is done.

The Attack Lifecycle (8 Steps)

1. **Reconnaissance (Recon):** The "snooping" phase. The attacker gathers as much information as possible about the target before launching a single packet.
    - **Passive Recon:** Gathering info *without* touching the target's network. (e.g., reading LinkedIn profiles to find employee names, checking public DNS records, looking at job postings to see what firewall brand you use).
    - **Active Recon:** Touching the network directly. (e.g., Nmap port scans, ping sweeps). This is risky because it generates logs.
    - **Enumeration:** A deeper form of recon where the attacker extracts specific details, such as user account names, network share lists, and software versions.
2. **Social Engineering:**
    - Manipulating people to gain access. Why hack a firewall when you can call the receptionist and ask for the password? (See Section 5.3).
3. **Technical Exploit (Scanning):**
    - Using tools to find a digital way in.
    - **Port Scan:** Knocking on every "door" (port) of a server to see which ones are open.
    - **Ping Sweep:** Pinging every IP address in a subnet to see which devices are alive.
4. **Breach:**
    - The moment the attacker gains unauthorized access. This could be via a cracked password, a software vulnerability (exploit), or a phishing link.
5. **Escalating Privileges:**
    - Getting inside is just the start. Usually, the attacker enters as a low-level user (like a receptionist). They need to become an Admin.
    - **Vertical Escalation:** Going from a User account to an Admin/Root account.
    - **Horizontal Escalation:** Moving from one user's account to another user's account (lateral movement).
6. **Create a Backdoor (Persistence):**
    - Attackers don't want to break in every single time. They install a "Backdoor" or **Remote Access Trojan (RAT)**.
    - This ensures they can return even if the original hole they used is patched.
7. **Staging:**
    - The attacker prepares the compromised system for the final goal. This might involve downloading extra hacking tools, disabling the antivirus, or setting up a command-and-control (C2) link.
8. **Exploit (The Goal):**

    - The final objective is achieved. This could be **Data Exfiltration** (stealing files), **Encryption** (Ransomware), or **Destruction** (wiping servers).

Common Network Attacks

- **DoS (Denial of Service):**
    - **Concept:** One computer flooding a server with so much traffic that it crashes or becomes too busy to serve legitimate users.
    - **Goal:** Availability (disruption), not theft.
- **DDoS (Distributed Denial of Service):**
    - **Concept:** An attack using a **Botnet**—thousands of infected "zombie" computers controlled by one attacker. They all flood the target simultaneously.
    - **Difficulty:** Extremely hard to stop because the traffic comes from legitimate IP addresses all over the world.
- **On-Path Attack (Man-in-the-Middle / MitM):**
    - **Concept:** The attacker secretly inserts themselves between two parties (e.g., You and the Bank). They relay messages back and forth, reading or modifying them without either side knowing.
    - **ARP Poisoning (Spoofing):**
        - **Mechanism:** The attacker sends fake ARP messages to the switch, claiming "I am the Router!"
        - **Result:** The switch sends all internet traffic to the attacker's laptop instead of the real router. The attacker then forwards it to the router, intercepting everything.
    - **DNS Poisoning:**
        - **Mechanism:** The attacker corrupts the DNS cache on a computer or server.
        - **Result:** When you type "www.google.com," the DNS server sends you to the attacker's fake IP address instead of the real Google IP.

5.3 Social Engineering

Definition: A tactic where the goal is to use deception, manipulation, and trickery to convince unsuspecting users to provide sensitive data or violate security guidelines. It exploits the human weakness rather than software bugs.

Core Defensive Tenants

To stop social engineering, you must build a culture of security.

- **Defense in Depth (Layering):** Implementing multiple strategies. If the user fails (clicks a link), the technology (firewall/AV) should catch it.
- **Principle of Least Privilege:** If a user is tricked, they should only have access to their own files, preventing the attacker from reaching the whole network.
- **Simplicity:** Security measures should be easy to understand. If they are too complex, users will bypass them.
- **Variety:** Using different vendors and methods (e.g., a Cisco firewall and McAfee antivirus) to ensure a single exploit doesn't bypass all layers.

Social Engineering Attack Vectors

1. Digital Deception (Remote)

- **Phishing:** Sending a generic malicious email to thousands of people (casting a wide net). "Click here to reset your password."
- **Spear Phishing:** Targeting a *specific* person or department. The email uses personal details ("Hi Bob, regarding the Q3 Invoice...") to look legitimate.
- **Whaling:** Spear phishing a "Big Fish" (CEO, CFO). These attacks are highly customized and sophisticated.
- **Vishing (Voice Phishing):** Using the phone or VoIP. "This is Microsoft Support, we detected a virus on your computer."
- **Smishing (SMS Phishing):** Using text messages. "Your package delivery failed, click here to reschedule."
- **BEC (Business Email Compromise):** An impersonation attack where the hacker compromises a CEO or Manager's email and instructs finance to "wire money immediately."
- **Pharming:** Redirecting users from a legitimate website to a malicious one, usually by poisoning the DNS server. You type `bank.com`, but you land on the hacker's site.
- **Typosquatting (URL Hijacking):** Registering domains that are slight misspellings of popular sites (e.g., `gooogle.com` or `faceboook.com`) hoping a user makes a typo.
- **Watering Hole Attack:** The attacker guesses where the target group "hangs out" online (e.g., a local gym website) and infects that specific site with malware, waiting for the targets to visit.

2. Physical & Interpersonal

- **Impersonation:** Pretending to be someone else (e.g., "Hi, I'm the HVAC repair guy").
- **Pretexting:** Creating a fake scenario or story to gain trust *before* asking for the data. (e.g., "I'm from IT, we are migrating servers and I need your login to sync your account").
- **Tailgating (Piggybacking):** Following an authorized person through a secure door without using a badge.
    - *Defense:* Mantraps (a small room with two doors where only one opens at a time).
- **Dumpster Diving:** Digging through trash to find bank statements, org charts, or password sticky notes.
    - *Defense:* Shredding policies.
- **Shoulder Surfing:** Looking over someone's shoulder to see their password or screen.
    - *Defense:* Privacy filters (screen protectors).

5.4 Malware

"Malware" (Malicious Software) is the catch-all term for any bad code. You need to know the specific types based on how they spread and what they do.

Infection Types (How it spreads)

- **Virus:** Malware that needs a host. It attaches itself to a legitimate file (like `game.exe`). It only runs when you click that file.

- **Worm:** Malware that needs no host and no user action. It is self-replicating. It jumps from computer to computer over the network automatically using vulnerabilities.
  - ***Analogy:*** A Virus is a sick passenger on a plane; a Worm is a missile.

- **Trojan (Trojan Horse): Malware disguised as legitimate software.**
  - ***Example:*** You download a "Free Screensaver." It installs the screensaver (the cover), but also installs a keylogger in the background.

Payload Types (What it does)

- **Rootkit:** Malware that digs deep into the OS (Kernel level) to hide itself. It can trick the Task Manager into showing "System Normal" even when the virus is running. It is extremely hard to remove; usually, you must wipe the drive.

- **Ransomware:**
  - **Action:** Encrypts all your files with military-grade encryption
  - **Goal:** Extortion. "Pay us 5 Bitcoin to get the decryption key."
  - ***Defense:*** Offline backups. If you can restore your data, you don't have to pay.

- **Botnet:** A network of infected computers (Zombies) controlled by a single attacker (Bot Herder) via a Command & Control (C2) server. Used for DDoS attacks or spam.

- **RAT (Remote Access Trojan):** A specific type of Trojan that gives the attacker full remote control (GUI access) of your machine. They can watch your screen, move your mouse, and turn on your webcam.

- **Logic Bomb:** Code that lies dormant until a specific condition is met.
  - ***Example:*** A disgruntled IT admin writes a script: "If my name is removed from the payroll system (I get fired), delete all the servers."

- **Keylogger:** Software (or hardware) that records every keystroke to steal passwords and credit card numbers.

- **Spyware:** Software that quietly gathers information about a user's activity (browsing history, cookies) without their consent**.**

- **Adware:** Software that displays unwanted pop-up advertisements. While annoying, it is often less malicious than spyware, but can still track users.

- **Crypto-mining (Cryptojacking):** Malware that hijacks your CPU/GPU power to mine cryptocurrency for the attacker. Symptom: Computer is extremely slow and fans are running at 100%.

- **PUP/PUA (Potentially Unwanted Program/Application):** Software that isn't technically a virus (it has an EULA), but is annoying and unwanted (e.g., browser toolbars, "weather" apps).

Malware Prevention Strategies

- **Patches:** Keep OS and applications up to date to close the holes Worms use.

- **Anti-Malware:** Signature-based (looks for known viruses) and Heuristic-based (looks for suspicious behavior).

- **Firewall:** Blocks unauthorized outbound connections (preventing C2 callbacks).

- **Sandboxing:** Running suspicious files in an isolated environment to see what they do before letting them on the real network.

Domain 6: Cryptography

Domain 6 covers the science of keeping secrets. It is the mathematical foundation that allows us to send credit card numbers over the internet without them being stolen. This domain starts with 6.1 (Foundational Concepts), defining the basics like Hashing, Salts, and the difference between "encoding" and "encrypting." Next, 6.2 (Symmetric Cryptography) covers "single-key" systems like AES, which are fast and used for bulk data. 6.3 (Asymmetric Cryptography) introduces the "two-key" systems (Public/Private) like RSA and ECC that solve the problem of secure key exchange. 6.4 (Advanced Crypto) looks at specialized tools like Blockchain, TPM chips, and Homomorphic encryption. 6.5 (PKI - Public Key Infrastructure) explains how digital certificates work to create "Trust" on the web (HTTPS). Finally, 6.6 (Cryptographic Attacks) details how hackers try to break these systems using Rainbow Tables and Collisions.

6.1 Foundational Concepts

Key Terms

- **Plaintext (Cleartext):** The readable message (e.g., "Hello").
- **Ciphertext:** The scrambled, unreadable message (e.g., "X7f#9@z").
- **Cipher:** The mathematical formula (algorithm) used to convert Plaintext to Ciphertext.
- **Key:** A random string of bits used by the Cipher. The security lies in the *Key*, not the Algorithm.
- **Security through Obscurity:** A bad practice. Hiding how the system works (using a secret algorithm) instead of using strong math. Modern crypto uses *public* algorithms (like AES) that everyone knows, but relies on *private* keys.
- **Steganography:** Hiding data *inside* other data.
    - *Example:* Hiding a text file inside the pixels of a JPEG image. The image looks normal, but contains a secret message.
- **Obfuscation:** Making code difficult to read (spaghetti code) to prevent reverse engineering, but not technically encrypting it.

Hashing

- **Hash:** A unique, fixed-length digital fingerprint that identifies a block of data and ensures its **integrity**.
- **Hashing:** The process of converting a value into a hash. Hashes are:
  - **Deterministic:** The same input *always* produces the same output.
  - **Fast:** Created quickly.
  - **One-Way:** Not decryptable (you can't turn the hash back into the original data) .
  - **Unique (Collision-Resistant):** Different data should always produce a different hash.
- **Hashing Applications:** Verifying password (storing hashes of passwords, not the passwords themselves), verifying file integrity (does the downloaded file's hash match the original?), and creating digital signatures .
- **Salt:** A random string added to a password *before* hashing it ("salting the hash"). This combats **rainbow tables** (pre-computed hash databases) because the attacker would need a separate table for every possible salt.

Hashing Algorithms

- **SHA-1 (Secure Hash Algorithm 1):** 160-bit key. Now considered weak and deprecated.
- **SHA-2 (Secure Hash Algorithm 2):** A family of hashes, most commonly **SHA-256** (256-bit key). This is the modern standard.
- **MD5 (Message Digest 5):** 128-bit key. This algorithm is computationally "broken" and has known collisions. **Do not use this for security**.

6.2 Symmetric Cryptography

"Symmetric" means "Same." The **same key** is used to both Encrypt and Decrypt.

- **Pros:** Extremely **Fast** and efficient. Ideal for encrypting large files (Hard Drives, Zip files).
- **Cons: Key Exchange.** How do you send the key to the recipient securely? If you email it, a hacker can steal it.
- **Session Keys:** Symmetric keys are often called "Session Keys" because they are temporary and used for just one conversation.

Stream Ciphers vs. Block Ciphers

- **Stream Cipher:** Encrypts data one *bit* at a time.
  - *Example:* **RC4** (Older, WEP/WPA). Fast but prone to errors if used incorrectly.
- **Block Cipher:** Encrypts data in chunks (blocks).
  - *Example:* **AES** (Advanced Encryption Standard).

The Algorithms

- **AES (Advanced Encryption Standard):** The gold standard.
  - **Key Sizes:** 128, 192, or 256 bits.
  - **Use Case:** WPA2/WPA3 Wi-Fi, VPNs, Disk Encryption.
- **DES / 3DES:** Old, slow, and broken. Replaced by AES.
- **Blowfish / Twofish:** Alternatives to AES, but less common.

Block Ciphers

- **Concept:** A symmetric method that encrypts data **one block (chunk) at a time** .
- **Block Sizes:** Common sizes are 64, 128, or 256 bits. If the last block is too small, "padding" (extra random bits) is added.
- **AES (Advanced Encryption Standard):** The modern, recommended block cipher.

Block Cipher Modes of Operation

Mode	Description
Electronic Code Book (ECB)	The simplest mode. Each block is encrypted separately . **Disadvantage:** Blocks with identical plaintext (e.g., lots of white space in a document) generate identical ciphertext, creating a visible pattern. **Poor security**.
Cipher Block Chaining (CBC)	Uses an **Initialization Vector (IV)**—a random string. The IV is XORed with the first plaintext block. Each subsequent block uses the *ciphertext from the previous block* as its IV. This is more secure but slower, as blocks cannot be encrypted simultaneously.
Cipher Feedback (CFB)	Also uses an IV. The IV is *encrypted first*, and that output is XORed with the plaintext to create the ciphertext .
Output Feedback (OFB)	Identical to CFB, except the output of the *IV encryption* (not the ciphertext) is used as the input for the next round .
Counter Mode (CTR)	Uses a **Nonce** (a random string used once) combined with a **Counter** (which increments for each block) . The (Nonce + Counter) is encrypted, then XORed with the plaintext. This allows for parallel processing and is very fast.
Galois Counter Mode (GCM)	Provides **Authenticated Encryption** (both encryption *and* authentication/integrity). It works like Counter mode but combines the ciphertext with a special hash (MAC). It is efficient and widely used in network communications (TLS, SSH) .

6.3 Asymmetric Cryptography

"Asymmetric" means "Different." It uses a **Key Pair**.

1. **Public Key:** Given to everyone. Used to **Encrypt**.
2. **Private Key:** Kept secret by the owner. Used to **Decrypt**.
    - **The Analogy:** The Public Key is a padlock. Anyone can snap the padlock shut (encrypt) to lock a box. Only the person with the Key (Private Key) can open it.
    - **Pros:** Solves the Key Exchange problem.
    - **Cons:** Very **Slow**. (1,000x slower than symmetric).
- **Process:**
    1. **Bob** generates a key pair. He keeps his private key secret and publishes his public key.
    2. **Alice** gets Bob's public key. She encrypts her message using **Bob's public key**.
    3. Alice sends the ciphertext to Bob.
    4. An attacker, **Mallory**, might sniff the network and see the ciphertext, but she *cannot* decrypt it .
    5. **Bob** is the only one who can decrypt the message, because he is the only one with the matching **private key**.

Asymmetric Algorithms

- **RSA (Rivest-Shamir-Adleman):** Created in 1977 . Still commonly used for creating digital signatures and public/private keys.
- **ECC (Elliptic Curve Cryptography):** A newer, more powerful method (1985). It provides the same level of security as RSA but with much *smaller keys*, making it more efficient and ideal for low-power devices and websites .
- **Diffie-Hellman:** This is a **key-exchange algorithm**, *not* an encryption algorithm. Its purpose is to allow two users who have never met to *safely create a shared symmetric key* over a public channel (like the internet) . It solves the "key exchange problem" for symmetric encryption.
- **DSA (Digital Signature Algorithm):** Proposed by NIST in 1991 . As the name implies, it is used *only* for creating digital signatures, not for encryption.

6.4 Advanced Crypto & Implementations

Key Terms

- **Digital Signature:** A combination of a **hash** of the data and the sender's **private key** . It provides **Integrity** (proves the data wasn't changed) and **Non-Repudiation** (proves the sender *is* who they claim to be and cannot deny sending it) .
- **Data Masking:** A de-identification method where generic or placeholder labels are substituted for real data (e.g., John S. becomes User A).
- **Tokenization:** A de-identification method where a unique, non-sensitive token is substituted for real data (e.g., 4111-1111-1111-1111 becomes tok_8a4b2c).
- **PGP (Pretty Good Privacy) / GPG (GNU Privacy Guard):** PGP was developed in 1991 . GPG is the open-source, command-line version (1999) . They are hybrid crypto models used heavily for encrypting emails.
- **Blockchain:** An expanding list of transactional records (a "ledger") secured using cryptography .
    - **Node:** A computer that participates in the network by maintaining a copy of the ledger and validating transactions.
    - **Mining:** The computational "Proof-of-Work" process by which new transactions are validated, bundled into blocks, and added to the chain.
    - **Decentralized Ledger:** No single authority controls the network. Blocks are chained together via the hash of the previous block, making the ledger tamper-evident .

Digital Signatures

How do you prove an email actually came from the CEO and wasn't changed?

- **The Process:**
    1. The Sender Hashes the email (Integrity).
    2. The Sender encrypts the hash with their Private Key (Authentication).
- **Result: Non-Repudiation.** Only the CEO's private key could have created that signature.

Specialized Cryptography

- **Lightweight Cryptography:**
    - **Explanation:** Encryption algorithms standardized by NIST (2018) for use on **Internet of Things (IoT) devices** .
    - **Purpose:** IoT devices have limitations like small RAM, low CPU power, and low battery life . These algorithms must be efficient while still providing high security.
- **Homomorphic Encryption:**
    - **Explanation:** An asymmetric encryption method that allows data to be *worked on (computation) without decrypting it first* .
    - **Types:**
        - **Partially (PHE):** Allows *one* simple math function (e.g., addition) an unlimited number of times.
        - **Somewhat (SHE):** Allows more complex math (e.g., multiplication), but only a *limited* number of times.
        - **Fully (FHE):** Allows *all* math functions an *unlimited* number of times. It is still in development and is slow/inefficient.
- **Blockchain:** A decentralized, distributed ledger. Integrity is maintained by chaining blocks together using Hashes.

Cryptographic Hardware

- **TPM (Trusted Platform Module):**
    - **Explanation:** A secure crypto-processor chip built *into the motherboard* of many modern computers .
    - **Function:** It provides secure, hardware-based storage of encryption keys, hashed passwords, and other platform-identification information. (e.g., used by Windows BitLocker).
- **HSM (Hardware Security Module):**
    - **Explanation:** This is the "TPM on steroids". It is a high-performance, *external* device.

  - **Function:** Generates and stores keys, digital signatures, and smart card keys at a high volume for enterprise use .

6.5 Public Key Infrastructure (PKI)

Definition: PKI is not a single thing, but a *system* of technologies, policies, and processes that manages digital keys and **certificates** to secure communication and verify identities online.

Digital Certificates (X.509)

An electronic document that binds a Public Key to an Identity.

- **Contents:** Public Key, Expiration Date, CA Signature, **CN (Common Name)** (e.g., `www.google.com`).
- **SAN (Subject Alternative Name):** An extension that allows one cert to cover multiple domains (`www.google.com`, `mail.google.com`, `drive.google.com`).
- **Wildcard:** Covers subdomains (`*.google.com`).

PKI Components & Process

- **Certificate Authority (CA):** A reputable, trusted 3rd-party organization (like DigiCert or Let's Encrypt) that issues and vouches for the authenticity of keys and certificates .
- **Registration Authority (RA):** An entity that *verifies a user's identity* before the CA issues a certificate.
- **Digital Certificate:**
  1. **Explanation:** An electronic document that uses the **X.509 standard** to bind a public key to an identity (like a person or a website). This is the "Digital ID" that proves a server is who it claims to be.
  2. **Attributes:** Contains the Serial number, Signature algorithm, the subject's **Public key**, Expiration date, and **Common Name (CN)** (the domain name, e.g., google.com) .
- **Certificate Signing Request (CSR):**
  1. **Explanation:** A file generated on a server that contains its identifying information (like its Common Name) and its public key.
  2. **Process:** This file is sent to a CA to *request* a digital certificate. The CA validates the company's identity, signs the request, and sends back the official certificate .
- **CRL (Certificate Revocation List):** A blacklist of certificates that have been revoked before their expiration date (e.g., because the private key was stolen).
- **OCSP (Online Certificate Status Protocol):** A real-time check. Instead of downloading the whole CRL, the browser asks the CA: "Is *this specific* cert still good?

- **Chain of Trust:**
    1. **Explanation:** The method of validating a certificate by tracing its signature up a hierarchy to a trusted **Root CA**.
    2. **Structure:** A **Root Certificate** (which is self-signed) is used to sign one or more **Intermediate Certificates**. These intermediates then sign the end-user certificates. Your browser trusts the Root, so it can trust the intermediate, and therefore it trusts the website.
- **Key Lifecycle:** The management of a key from beginning to end:
    1. Key Generation
    2. Key Establishment
    3. Key Storage
    4. Key Usage
    5. Key Archival (backing up keys, often with a trusted third party, known as **escrow**)
    6. Key Destruction

Certificate Revocation

Certificates do not last forever and *must* be renewed before their expiration date . They can also be revoked early.

- **Reasons to Revoke:** The private key was compromised, the organization no longer exists, or the certificate was issued fraudulently . A revoked certificate *cannot* be reinstated.
- **Certificate Revocation List (CRL):** A *blacklist* of all certificates that have been revoked . A browser would have to download this entire (potentially large) list.
- **Online Certificate Status Protocol (OCSP):** A *real-time* system used to check the status of a *single* certificate. This is much faster and more efficient than downloading a CRL.

Certificate Types & Validation

- **Validation Levels (How much "vetting" the CA does):**
    - **Domain Validation (DV):** The lowest, cheapest level . The CA only verifies that the applicant controls the domain name (e.g., via an email or phone call) . Issued in minutes.
    - **Organization Validation (OV):** Includes DV *and* proves the organization is a real, legitimate legal entity . Takes 1-3 days.
    - **Extended Validation (EV):** The highest level of trust . Includes DV and an *in-depth* validation of the organization. Takes 1-5 days.
- **Common Certificate Types:**
    - **Subject Alternative Name (SAN):** An extension that allows *multiple different domain names* (e.g., testout.com, testout.net, labsim.com) to be secured with a **single certificate**.

- **Wildcard Certificate:** Covers *one domain and all of its subdomains* at a certain level (e.g., *.testout.com covers quiz.testout.com, labs.testout.com, etc.) .
- **Code-Signing Certificate:** Used by app developers to digitally sign their applications . This proves the app is legitimate and hasn't been tampered with. If an app isn't signed, users get a warning.
- **Self-Signed Certificate:** A certificate that is not validated by a CA; it's signed by the entity that issued it. They are easy and free to make but provide no security or trust, and will generate a large warning in all browsers.
- **Email Certificate (S/MIME):** Uses the S/MIME protocol to send encrypted and digitally signed email. The certificate contains the user's public key .
- **User/Computer Certificate:** Used in a network environment (like Active Directory) to identify and validate specific users or computers when they log in, providing an extra layer of security.

6.6 Cryptographic Attacks

Breaking encryption isn't about guessing the key (which is mathematically impossible with AES-256); it's about finding shortcuts, exploiting weak implementations, or stealing the key outright.

Password Attacks

- **Brute Force:**
  - **Concept:** Trying every possible combination of characters (A, B, C... AA, AB...).
  - **Online Brute Force:** Trying to log in to a live website. This is slow and easily detected by account lockouts.
  - **Offline Brute Force:** Stealing the hash file (e.g., `/etc/shadow`) and cracking it on a powerful gaming rig. This is very fast because there are no rate limits.
- **Dictionary Attack:**
  - **Concept:** Trying only words found in a dictionary or a common password list (like `rockyou.txt`).
  - **Defense:** Enforce password complexity (require symbols and numbers) so the password isn't a dictionary word.
- **Rainbow Table Attack:**
  - **Concept:** A "Cheat Sheet" for hackers. It is a massive database of pre-calculated hashes for every possible password. Instead of hashing "password123" to see if it matches, the hacker just looks up the hash in the table to find the password instantly.
  - **Defense: Salt.** Adding a random string to the password *before* hashing it invalidates the pre-calculated table.

Algorithm Attacks

- **Collision Attack:**
  - **Concept:** Finding two *different* input files that produce the exact *same* Hash.
  - **Why it matters:** If a hacker can create a malicious file that has the same hash as a legitimate file, they can trick the system into accepting it.
  - **Birthday Attack:** A statistical phenomenon that makes finding collisions easier than you'd expect (named after the probability that two people in a room share a birthday).
- **Downgrade Attack:**
  - **Concept:** Tricking a server into abandoning a secure protocol (like TLS 1.3) and falling back to an older, vulnerable one (like SSL 3.0).
  - **Mechanism:** The attacker (Man-in-the-Middle) interferes with the connection handshake, telling the server "I don't support modern encryption."
  - **Defense:** Disable old protocols on the server side completely.
- **Replay Attack:**

- **Concept:** The attacker captures a valid data transmission (like a hash of your password or a session token) and "replays" it later to trick the system.
- **Defense:** Use **Session Tokens** with timestamps or "Nonces" (Number used ONCE) so old data is rejected.

Domain 7: Identity & Access Management (IAM)

Domain 7 focuses on the most fundamental question in security: "Who are you, and what are you allowed to do?" It starts with **7.1 (Authentication Technologies)**, which covers the protocols that allow users to sign in once and access everything (SSO, Federation). Next, **7.2 (Hardening Authentication)** details how to make those logins secure using MFA and Biometrics. **7.3 (Access Control Lists & Permissions)** explains the math behind "Allow" and "Deny" rules. **7.4 (Active Directory)** covers the Microsoft way of managing enterprise networks (Domains, Trees, Forests). Finally, **7.5 (Linux Users & Groups)** dives into the command line, detailing how Linux stores passwords and manages user accounts.

7.1 Authentication Technologies

Authentication is the process of *proving* you are who you say you are. These technologies manage that process.

Key Terms

- **IAM (Identity and Access Management):** The framework of policies and technologies for ensuring that the right people have the right access to technology resources.
- **SSO (Single Sign-On):** A session and user authentication service that permits a user to use one set of login credentials (e.g., name and password) to access multiple applications.
  - *Example:* Logging into your school/work portal once and then clicking on Email, Canvas, and Zoom without logging in again.
- **Directory Services:** A centralized database that stores all user accounts, passwords, and computer information for a network (e.g., Microsoft Active Directory).
- **Federation:** A method of linking a user's identity across multiple distinct security domains. It allows you to use your credentials from Company A to access resources at Company B.
  - *Real-World:* "Log in with Facebook" or using your University ID to access a research library database.
- **Attestation:** The process of a device proving its identity and integrity to a remote verifier. "I am a corporate laptop, and my boot process hasn't been tampered with."

Network Authentication Protocols

These are the languages servers use to talk to "Authentication Servers" (the bouncers).

- **RADIUS (Remote Authentication Dial-In User Service):**
  - **Type:** The industry standard for network access (VPNs, Wi-Fi).
  - **Protocol:** UDP (Ports 1812/1813).
  - **Security:** Encrypts *only* the password packet.
  - **Use Case:** When you log into the corporate Wi-Fi using your username/password, the AP talks to a RADIUS server.
- **TACACS+ (Terminal Access Controller Access-Control System Plus):**
  - **Type:** Cisco Proprietary (mostly).
  - **Protocol:** TCP (Port 49).
  - **Security:** Encrypts the *entire* packet (much more secure than RADIUS).
  - **Use Case:** Admins logging into Routers/Switches to manage them. It separates Authentication, Authorization, and Accounting (AAA) into distinct processes.
- **Kerberos:**
  - **Type:** The default authentication protocol for **Active Directory**.
  - **Mechanism:** Uses "Tickets" (Ticket Granting Ticket - TGT) to allow users to access resources without re-typing passwords.
  - **Requirements:** Relies heavily on **Time Synchronization** (NTP). If your clock is off by more than 5 minutes, login fails to prevent Replay Attacks.
  - **Mutual Authentication:** The Client verifies the Server, AND the Server verifies the Client.
- **802.1X (Port-Based NAC):**
  - **Type:** A standard for controlling access to a wired or wireless network port.
  - **Function:** The switch port is "dead" until you authenticate. Once you pass the 802.1X check (via EAP), the port opens.

Federation & Single Sign-On (SSO)

How do we log in once and access apps across the internet?

- **SSO (Single Sign-On):**
  - **Concept:** Logging in once establishes a "Session" that other apps trust.
  - **Federation:** Linking identity across different organizations (e.g., using your Google ID to log into Spotify).
- **SAML (Security Assertion Markup Language):**
  - **Format:** XML-based (older, heavier code).
  - **Use Case:** Enterprise SSO. Commonly used for logging into corporate web apps like Salesforce or ServiceNow.
- **OAuth (Open Authorization):**
  - **Purpose: Authorization** only.
  - *Analogy:* Giving a Valet key to a parking attendant. The key opens the door and starts the car (limited access), but doesn't open the trunk or glovebox. You grant

a website access to your Google Contacts without giving them your Google Password.

- **OpenID Connect (OIDC):**
    - **Purpose: Authentication.** Built on top of OAuth.
    - *Function:* This is the layer that actually handles the "Sign in with Google" button. It uses JSON (lighter/faster than XML).
    -

7.2 Hardening Authentication

"Hardening" means strengthening your authentication methods to make them more resistant to attack.

Key Terms

- **Smart Card:** A card, similar to a credit card, that has an embedded memory chip containing encrypted authentication information.
- **RFID (Radio Frequency Identification):** The wireless, non-contact use of radio waves to transfer data, often used in access badges.
- **Microprobing:** An attack that involves physically accessing a smart card's chip surface to observe and interfere with its circuit.

Hardening Methods

- **User Education:** This is a critical first step. Users should be trained to create memorable passwords, not write them down, understand social engineering, and not share access.
- **Stronger Passwords:** Enforce strong password policies:
    - **Password Aging:** Forcing users to change their password after a set time.
    - **Password History:** Preventing users from re-using their last X passwords.
    - **Password Complexity:** Requiring a mix of upper, lower, numbers, and symbols.
- **Multifactor Authentication (MFA):**
    - **Explanation:** Using more than one *method* (or factor) to authenticate.
    - **The Factors:**
        1. **Something you know:** A password, PIN, or security question.
        2. **Something you have:** A smart card, RFID token, or a one-time-password app on your phone.
        3. **Something you are:** A fingerprint, face scan, or iris scan (biometrics) .
    - **Note:** True 2-Factor Authentication (2FA) must use at least *two different* factors. A password and a PIN are *not* 2FA, as they are both "something you know".
- **Account Restrictions & Monitoring:**
    - **Restrictions:** Set policies to limit risk, such as: **Time-of-day restrictions** (e.g., employees can only log in from 9-5), setting an **account lockout threshold** (e.g., 5 failed attempts locks the account), and configuring a lockout counter reset .
    - **Monitoring:** Actively log login history, login location, incorrect password use, and password resets to spot anomalies.
- **Manage Old/Inactive Accounts:**
    - **Explanation:** Old accounts are a major security risk.
    - **Policy:** Delete old employee accounts (part of "offboarding"), disable accounts that have been inactive for X days, and set automatic account expiration for temporary accounts.
- **Manage Access Levels:**
    - **Domain Accounts:** Stored on the Domain Controller and managed by admins .
    - **Local User Accounts:** Stored locally on a machine. **Best Practice:** Do not have *any* local admin accounts, rename the default "Administrator" account, create only standard users, and disable the "Guest" user account.
    - **Remote Access:** Be very restrictive. Limit who can connect remotely, force them to connect through a secure **DMZ**, restrict the IP addresses that are allowed to connect, and audit all remote logins.

7.3 Access Control Lists (ACLs) & Permissions

Once a user is Authenticated (Identity proven), we must determine Authorization (Permissions).

Key Terms

- **ACL (Access Control List):** A list of permissions attached to an object (like a file or folder).
- **ACE (Access Control Entry):** A single entry in an ACL that specifies permissions (e.g., "Allow" or "Deny") for a specific user or group.
- **Security Principal:** An object that can be assigned permissions, such as user accounts, computer accounts, and security group accounts. Each has a unique **Security Identifier (SID)**.
- **Access Token:** A digital token created when a user logs in. It contains the user's SID, all group SIDs the user belongs to, and their rights/privileges.
- **Implicit Deny:** If a user is not explicitly granted access, they are denied by default.

How Permissions are Calculated

- **Effective Permissions:** Access rights are **cumulative**. If you are in two groups (one has "Read" and one has "Write"), your *effective permission* is the combination of both ("Read" + "Write") .
- **Deny Permissions: Deny permissions *always* override Allow permissions**. If you are in one group that is "Allowed" and another group that is "Denied," you are **Denied**.
- **Inheritance:** Permissions granted to a parent container (folder) automatically flow down to the child objects (files and subfolders) within it .
- **The Exception (Explicit vs. Inherited): Explicit permissions *override* inherited permissions** . This is the one time a "Deny" might not win. If a folder has an *inherited Deny* but you add an *explicit Allow* directly to a file inside it, the explicit Allow will win.

7.4 Active Directory (Windows IAM)

Active Directory (AD) is Microsoft's centralized directory service. It allows for centralized management of resources, security administration, and single sign-on for all users in a Windows domain.

Key Terms

- **Domain:** An administratively defined collection of network objects (users, computers, printers) that share a common directory database and security policies .
- **Domain Controller (DC):** A Windows server that holds a copy of the Active Directory database. Any change made to one DC is copied to all other DCs through **replication** .
- **Tree:** A group of related domains that share the same contiguous DNS namespace (e.g., sales.company.com and hr.company.com).
- **Forest:** A collection of related domain trees. This is the top-level container in AD .
- **Object:** Each resource in AD is an object (e.g., User, Group, Computer, Printer).
- **Organizational Unit (OU):** A container (like a folder) used to subdivide and organize objects within a domain. OUs are essential for simplifying security administration, as you can apply policies to an entire OU at once.
- **Built-In Containers:** Default containers that look like OUs but *are not*. They are created by default and cannot be manually created, moved, renamed, or deleted.

The Structure

- **Domain:** A logical group of computers and users that share a common database and security policy (e.g., `company.com`).
- **Domain Controller (DC):** The Windows Server that holds the database. It authenticates users (using Kerberos).
- **OU (Organizational Unit):** A "folder" inside the domain used to organize users (e.g., "Sales OU," "IT OU").
  - *Importance:* You apply **Group Policy** to OUs.
- **Forest:** The collection of all Domains and Trees in an organization. The top-level container.

Group Policy (GPO)

Instead of configuring 500 computers one by one, you use Group Policy.

- **Computer Configuration:** Applies to the machine (boot up). Enforces things like Windows Firewall settings or disabling USB ports.
- **User Configuration:** Applies to the person (login). Enforces things like Desktop Wallpaper or mapping the "H:" drive.
- **Group Policy Management:** This is the tool that allows an admin to push configuration settings from the domain controller to individual hosts, rather than configuring them one-by-one.
- **Computer Policies:**
  - **Applies to:** The *entire computer system*, affecting all users who log into it .
  - **Applied:** At system boot.
  - **Includes:** Software, scripts, password settings, network security.
- **User Policies:**
  - **Applies to:** A *per-user basis*, and can be unique for each user.
  - **Applied:** When the user logs in.
  - **Includes:** Software for one user, scripts, web browser security/favorites.

7.5 Linux Users and Groups

Linux is a multi-user OS. Its account information is stored in a set of configuration files in the **/etc** directory.

Critical Files

1. **`/etc/passwd`**: User account details. Readable by everyone.
2. **`/etc/shadow`**: The Hashes. Readable only by Root.
3. **`/etc/group`**: Group definitions.
4. **`/etc/gshadow`**: Group passwords.

User Management Commands

1. Creating Users (`useradd`)

- `useradd`: Creates a new user account.
  - `-c`: Adds a description (comment).
  - `-d`: Assigns a custom home directory.
  - `-e`: Specifies an expiration date (YYYY-MM-DD).
  - `-m`: Creates the user's home directory (if it doesn't exist).
  - `-s`: Defines the user's default shell (e.g., `/bin/bash`).

2. Managing Passwords (`passwd`)

- `passwd`: Assigns or changes a user's password.
  - `-S`: Displays the account status (e.g., `LK` for locked, `PS` for password).
  - `-l`: Locks (disables) an account.
  - `-u`: Unlocks an account.
  - `-d`: Removes the password (makes the account passwordless).
  - `-n`: Sets the minimum days before a password *can* be changed.
  - `-x`: Sets the maximum days before a password *must* be changed.

3. Modifying Users (`usermod`)

- `usermod`: Modifies an existing user account.
  - `-c`: Changes the description.
  - `-l`: Renames a user account.
  - `-L`: **Locks** the user account.
  - `-U`: **Unlocks** the user account.

4. Deleting Users (`userdel`)

- `userdel`: Removes (deletes) a user from the system.
  - `-r`: **Critical flag.** Removes the user's home directory and mail spool along with the account.
  - `-f`: Forces the removal, even if the user is currently logged in.

THINGS TO ADD

- More protocols (STP)
- More specifics with WEP, WPA